

PIEDPIN

CISSP for BEGINNER

なぜCISSPを学ぶのか

- ✓ CISSP(Certified Information Systems Security Professional)とは、世界標準の**セキュリティ・プロフェッショナル認定**です。
- ✓ (ISC)²（国際情報システムセキュリティ認証コンソーシアム、International Information Systems Security Certification Consortium）が認定を行っています。
- ✓ 情報セキュリティ専門家が共通言語として利用している『(ISC)² CISSP CBK』を理解している者のみに与えられる資格です。
- ✓ 2004年6月に、米国規格協会（ANSI）より**ISO/IEC17024**の認証を受け、信頼度がより高くなりました。（https://japan.isc2.org/cissp_about.html）
- ✓ 2022年7月1日現在、日本のCISSPは**3,699**人となっています。（<https://japan.isc2.org/>）

(ISC)² が展開する資格ソリューション



国際的に認められた情報セキュリティ・プロフェッショナル認定資格です。米国規格協会（ANSI）よりISO/IEC17024の認証を受けた。



ベンダーフリー・カントリーフリーの情報セキュリティの資格です。情報セキュリティに従事しないが、組織を理解し、適切なコミュニケーションを行う。



クラウドサービスを安全に利用するために必要な知識を体系化した資格です。



ソフトウェアの脆弱性に端を発したセキュリティインシデントの増加や、政府や重要インフラにおけるセキュアなソフトウェアニーズに対応する資格です。

(ISC)² CISSP CBK ドメイン



ドメイン 1
セキュリティとリスク
マネジメント



ドメイン 2
資産のセキュリティ



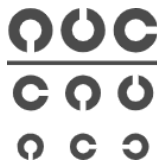
ドメイン 3
セキュリティアーキ
テクチャとエンジニ
アリング



ドメイン 4
通信とネットワー
クのセキュリティ



ドメイン 5
アイデンティティと
アクセスの管理



ドメイン 6
セキュリティの評
価とテスト



ドメイン 7
セキュリティの運用



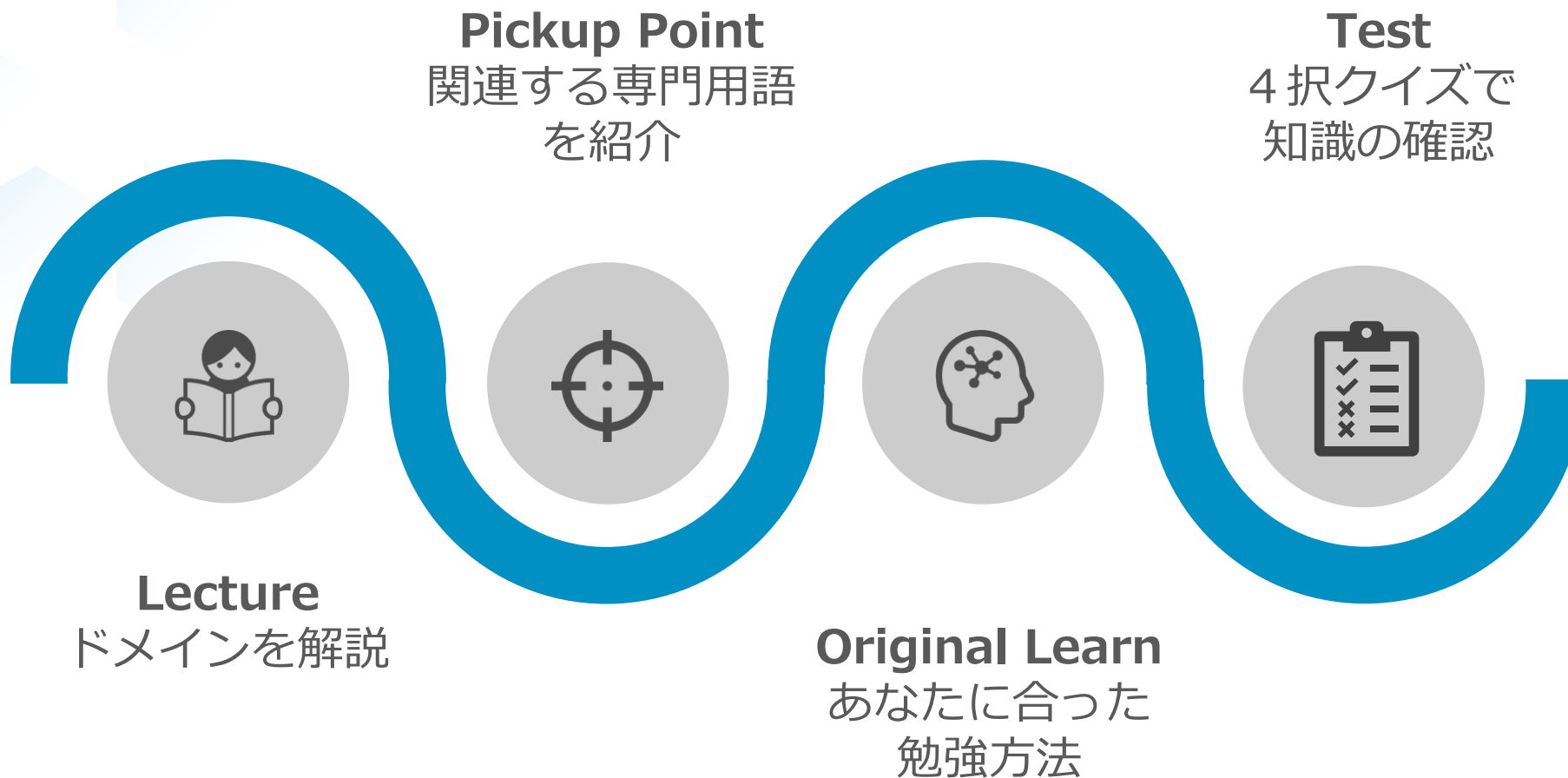
ドメイン 8
ソフトウェア開発
セキュリティ

あなたのゴールとレッスンの役割

- ✓ 情報セキュリティ初心者のために設計されたCISSP講座
経験者からすると“当たり前”と感じる内容も含まれます。
- ✓ 本レッスンの対象は、CBKのドメイン 4 です。
他のドメインのレッスンは対象外となります。
- ✓ CISSP合格のためのアップグレードが必要です。
現代のセキュリティの関心、流行、考え方を織り込みます。



レッスンの流れ



CISSP試験のドメイン別試験比重



ドメイン 1
セキュリティとリスク
マネジメント

15%



ドメイン 2
資産のセキュリティ

10%



ドメイン 3
セキュリティアーキテ
クチャとエンジニアリ
ング

13%



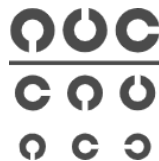
ドメイン 4
通信とネットワー
クのセキュリティ

13%



ドメイン 5
アイデンティティとア
クセスの管理

13%



ドメイン 6
セキュリティの評価
とテスト

12%



ドメイン 7
セキュリティの運用

13%



ドメイン 8
ソフトウェア開発セ
キュリティ

11%

DOMAIN 4 のカテゴリー



ネットワークモデル

- ネットワークタイプ
- レイヤーモデル
- トポロジー
- パケットアドレス
- アドレス変換
- ICMP/UDP/TCP



ネットワークデバイス

- ケーブル
- 中継機器
- ファイヤーウォール



セキュア通信

- 認証方式
- 通信暗号化



ネットワークエリア管理

- ワイドエリアネットワーク
- ワイヤレスネットワーク
- ストレージエリアネットワーク
- ソフトウェア定義ネットワーク
- 通信流量制御



アプリケーション通信

- ウェルノウンポート
- リモート接続
- リモートミーティング
- 産業通信



ネットワーク障害

- ネットワーク攻撃



ネットワークモデル

関連用語

- ARPAnet
- ARCNET
- 回線交換ネットワーク
- パケット交換ネットワーク
- サービス品質（QoS）
- OSI参照モデル
- TCP/IPモデル
- カプセル化
- ネットワークトポロジー
- MACアドレス
- IPアドレス
- NAT
- TCPフラグ
- TCPスリーウェイハンドシェイク

ネットワークモデル

ネットワークタイプ



●ネットワークの多層防御

- 通信は、外部の端末に対してデータを送信することです。受け取り手はそのデータを利用しサービスを提供したり、もしくはデータの送付側に処理結果を返却します。
- ネットワークの多層防御はシステムによる制御だけではありません。マルウェアがサーバーを攻撃する前に、ルーター、ファイアウォール、侵入検知システム、およびウイルス対策ソフトウェアなどによって検知します。その上、各ホストにはパッチが適用され、ユーザーにはマルウェアのリスクに対する認識がトレーニング等によって提供されています。いずれかが機能していなくとも、セキュリティ機能が損なうことはありません。つまり、多層防御です。

●通信伝達方法によるネットワーク分類

通信の際には、送信端末と受信端末が存在します。端末間の目的によっては通信の方向が区分されます。

- **単方向通信**とは、ラジオのように一方向のみの通信です。一般的に、送信元はデータを保持し、受け取り側はデータからサービスを提供する関係性になります。
- **半二重通信**とは、トランシーバーのように通信し合うが同時ではなく、どちらか一方が占有する通信です。
- **全二重通信**とは、対面で会話するように同時に送信および受信する通信です。



単方向通信



半二重通信



全二重通信

ネットワークモデル

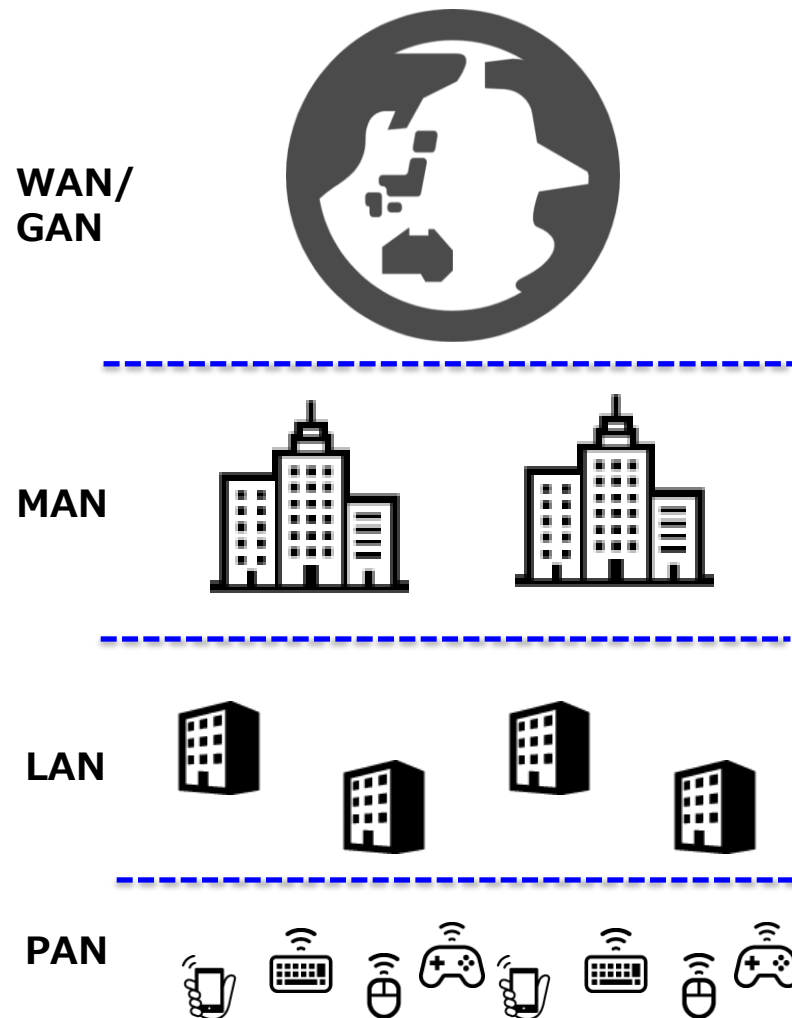
ネットワークタイプ



● 規模によるネットワーク分類

通信端末（ノード）と各端末通信から成るものをネットワークと言います。ネットワークは、規模に応じて区分する用語が存在します。

- **PAN (Personal Area Networks)** とは、Bluetoothなど近距離の端末通信に利用されるネットワークです。
- **LAN (Local Area Networks)** とは、建物または建物内のネットワークなどの比較的小さなエリアのネットワークです。
- **MAN (Metropolitan Area Networks)** とは、都市、大学キャンパス、オフィスパークのネットワークです。
- **WAN (Wide Area Networks)** とは、都市、州、または国のネットワークです。
- **GAN (Global Area Networks)** とは、地球規模のネットワークである。全地球情報グリッド（GIG、Global Information Grid）は、世界最大のネットワークの1つであり、米国国防総省（DoD、United States Department of Defense）が管理しています。



ネットワークモデル

ネットワークタイプ

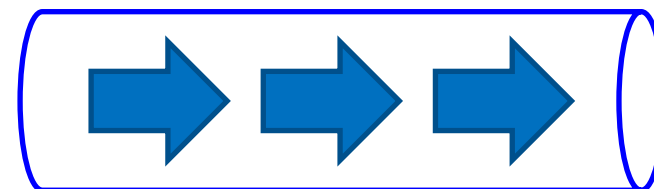
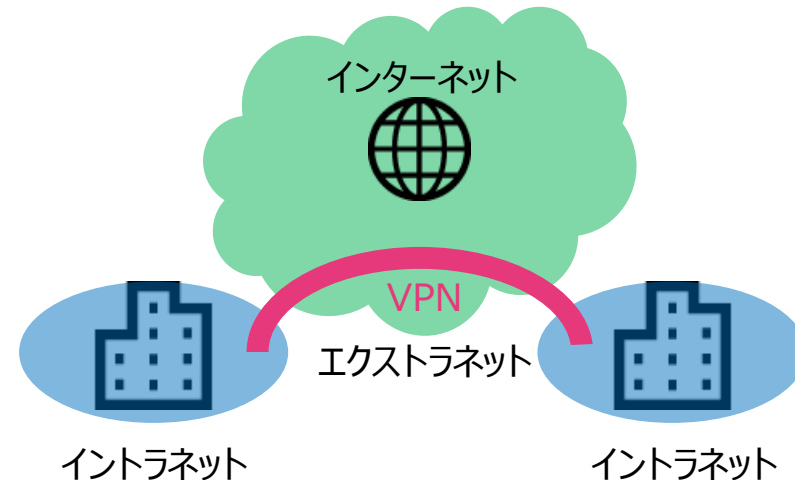
● 所有によるネットワーク分類

ネットワークは、自身でネットワーク機器を購入し構築することもあります。オープンに張り巡らされたネットワークを利用する場合もあります。

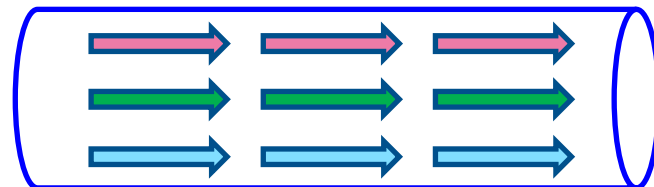
- **インターネット**とは、世界中でつながられているTCP/IPネットワークです。
- **イントラネット**とは、企業ネットワークなど個人所有のTCP/IPネットワークです。
- **エクストラネット**とは、ビジネスパートナーのイントラネットへの接続などプライベートイントラネット間のTCP/IPネットワークです。

● チャネル通信によるネットワーク分類

- **ベースバンドネットワーク**とは、チャネルが1つで通信するネットワークである。1度に1つの信号だけを送信します。家庭用でよく使われているイーサネットネットワークは、このベースバンドネットワークになります。
- **ブロードバンドネットワーク**とは、複数のチャネルを持つネットワークである。1度に複数の信号を送信します。ケーブルテレビに使われている複数のチャネルを持つネットワークです。



ベースバンド



ブロードバンド

ネットワークモデル

ネットワークタイプ

● 回線によるネットワーク分類

回線交換ネットワーク

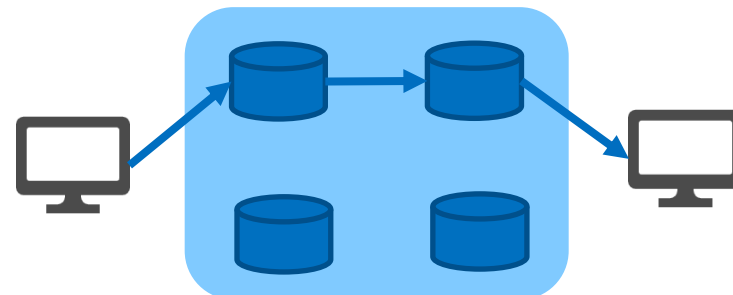
- 専用のチャネルを確保し通信を行うネットワークです。
- データを送信しなくとも専用でチャネルを保持しておくため、多くのチャネルを確保できず多くの通信を受け付けられない傾向があります。

パケット交換ネットワーク

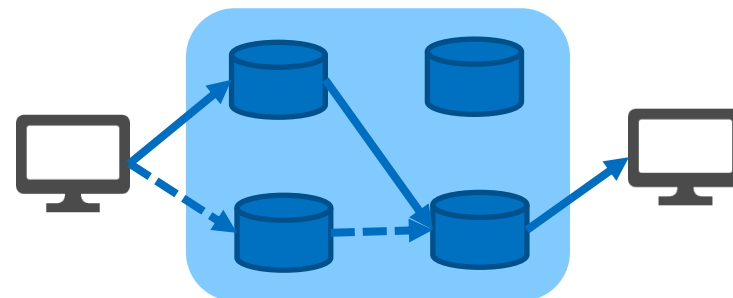
- 通信が必要なとき以外は回線を開放し、複数人が同じ回線を共有することができるネットワークです。広範囲のデータ通信においてはパケット交換方式の方が優れていると言えます。
- パケット交換ネットワークに関する最初の研究は、国防高等研究計画局（DARPA、Defense Advanced Research Projects Agency）における1960年代初頭に実施されました。その研究は、インターネットの前身であるARPAnetの作成に繋がっています。

サービス品質（QoS、Quality of Service）

- 他のトラフィックよりも特定のトラフィックを優先する仕組みです。
- 例えば、電話の通信に遅延が発生した場合、サービス自体の品質を著しく落とすが、Eメール送付は送付データが完全であれば、多少データの送付が遅くともサービスの品質は電話ほど落としません。



回線交換ネットワーク



パケット交換ネットワーク

ネットワークモデル

レイヤーモデル



● OSI (Open Systems Interconnection) 参照モデル

通信データとは、端末からアプリケーションが利用するデータからネットワーク機器が伝送するまでのデータまで保持している。通信データを正しく解釈するために、ネットワークモデルの概念が役立ちます。

階層	OSI参照モデル	内容
7	アプリケーション	Webブラウザ、ワードプロセッサなどを利用するための通信プロトコルHTTPやFTPなどを提供します。
6	プレゼンテーション	データ変換、ASCIIなどの文字セット、GIF、JPEG、TIFFなどの画像形式が含まれます。
5	セッション	単方向、半二重、全二重通信を制御する。また、TCPとUDPはセッション層にてセッションを管理し、複数のアプリケーションを同時に実行できる環境を提供します。
4	トランスポート	通信をサポートするパケットシーケンス、フロー制御、エラー検出を処理する。TCPは速度を犠牲にして通信内容の信頼性を担保し、UDPは信頼性よりも速度を選択します。
3	ネットワーク	レイヤー2までは同じLAN内の通信であるが、レイヤー3のIPアドレスを付け加えると他のLANにもアクセスが可能になる。ルーターなどのルーティングが含まれます。
2	データリンク	LANの通信を処理する。通信口にはそれぞれMACアドレスという番号が付けられており、同じLANにあるMACアドレス同士の通信を制御する。スイッチとブリッジが含まれます。
1	物理	光、電気、電波などのエネルギーで表されるビットを運ぶための媒体である銅線や光ファイバーケーブルを指す。ハブとリピータが含まれます。



ネットワークモデル

レイヤーモデル

●TCP/IPモデル

TCP/IPモデルは、OSI参照モデルとともに利用されます。システム実装においてはOSI参照モデルは区分が細かく、TCP/IPモデルの方がより適当です。

階層	OSI参照モデル	TCP/IPモデル	内容	データの呼び名	プロトコル例
7	アプリケーション	アプリケーション	コンピューターアプリケーションを展開するレイヤーである。	アプリデータ	HTTP、FTP、DNS、SMTP、POP
6	プレゼンテーション		アプリケーションの仕様ごとに扱いやすい方法でデータを提示する。	アプリデータ	SMTP、FTP、Telnet
5	セッション		単方向、半二重、全二重通信を制御する。	アプリデータ	TLS、NetBIOS
4	トランスポート	トランスポート	パケットシーケンス、フロー制御、およびエラー検出を処理する。	セグメント	TCP、UDP、Netware/IP
3	ネットワーク	インターネット	他のLANにもアクセスが可能になる。	パケット	IP、ARP、RARP、ICMP
2	データリンク	ネットワークインターフェース	LANの通信を処理する。	フレーム	PPP、Ethernet
1	物理		光、電気、電波などのエネルギーで表されるビットである。	ビット	RS-232、UTP、無線

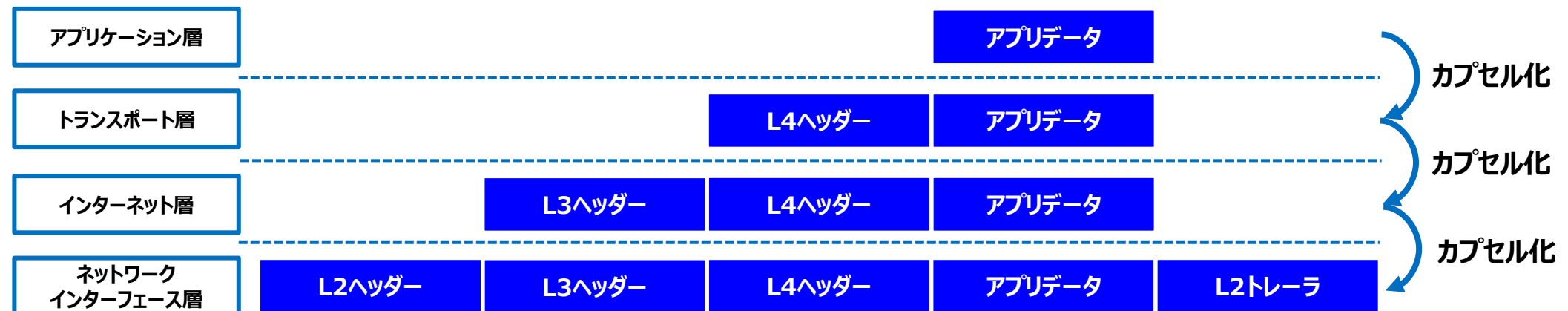


ネットワークモデル

レイヤーモデル

●カプセル化

カプセル化とは、アプリケーションで扱うデータを通信データとして使えるようにするための方法です。ネットワークモデルでは、階層型で示されるように実際のデータも上位層から情報を取得し、下層の制御情報をヘッダーとして追加します。送信側から通信データを生成するため、下層の通信ヘッダーを付与していきます。反対に、受信側は上層に通信ヘッダーを解釈していきます。これをデカプセル化と言います。



ネットワークモデル

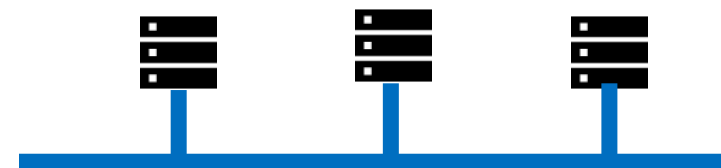
トポロジー

● ネットワークトポロジー

通信経路を確保するのので障害ポイントが変わるため、トポロジー他ネットワーク構成を考えるうえでは非常に重要です。

バス型

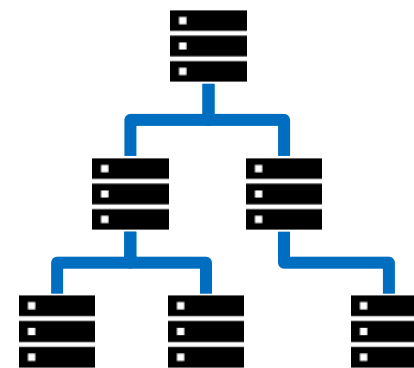
- 一つのケーブルに複数のノードを接続するトポロジーです。
- ケーブルが一つしかないため、ケーブルが断線などすれば、全体が通信できなくなります。



バス型

ツリー型

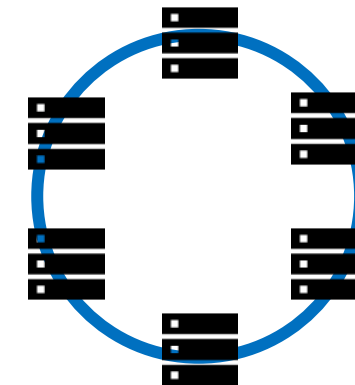
- 階層型ネットワークとも呼ばれます。最上位のノードから子ノードを広げていきます。



ツリー型

リング型

- リング状にノードを接続します。ノードからノードへのケーブルをたどるように通信します。



リング型

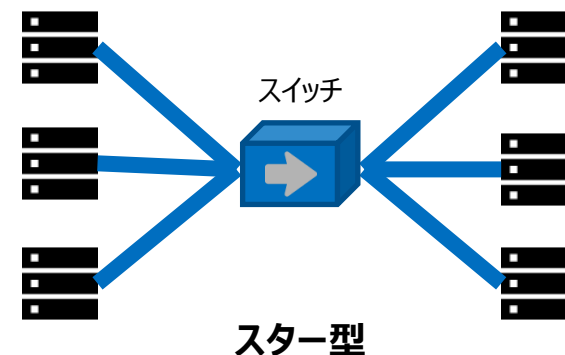
ネットワークモデル

トポロジー

● ネットワークトポロジー

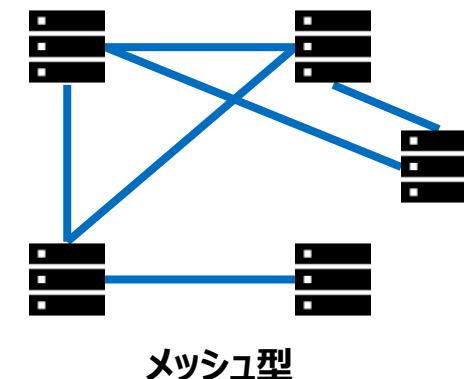
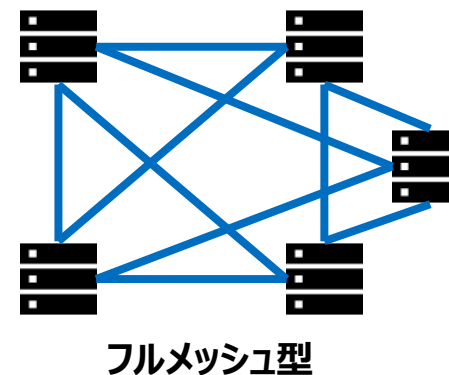
スター型

- 各ノードはハブやスイッチなどの中央デバイスに直接接続されます。
- 一つのローカルケーブル切断しても、接続されているノードのみ接続できなくなるだけで、全体には影響が出ません。
- 最初にARCNETによって普及し、後にイーサネットによって採用されました。
- すべてのノードが配線されているため、1本のケーブルでノードを接続するバス型とは異なりケーブルの消費が激しい特徴があります。



メッシュ型

- 通信端末同士で網のように、通信し合っているネットワーク構成です。
- すべての通信端末が他のすべての通信端末と接続されている構成をフルメッシュと言い、部分的に双方向通信を行っている構成を純粋にメッシュ型と言います。



ネットワークモデル

パケットアドレス

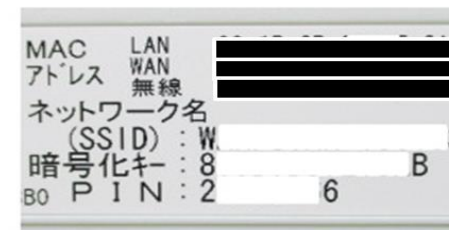


●MACアドレス (Media Access Control Address)

LAN内通信で利用されるネットワークインターフェイスカード (NIC、Network Interface Card) の一意に振られているデータリンク層のアドレスです。コンピュータは処理部分と通信自体は分離しており、ネットワークアドレスは端末ではなく通信口となるNICが保持しています。



有線LANのNIC



無線LANのNIC情報の記載

イーサネットフレームとMACアドレス

- MACアドレスはデータリンク層のアドレスであり、データリンク層の通信端末の伝送のために利用されます。

MACアドレスのフォーマット

- MACアドレスは48ビット長から構成され、前半24ビットはOUI (Organizationally Unique Identifier) と呼ばれるメーカーの識別番号、後半24ビットは各メーカーが一意に割り当てた番号です。

イーサネット通信のフレーム

ネットワーク インターフェイス層		インターネット層		トランスポート層		アプリケーション層	
MACアドレス		IPアドレス		ポート番号		データ	
宛先	送信元	宛先	送信元	宛先	送信元		

11-22-33-44-55-66

第1オクテット 第2オクテット 第3オクテット 第4オクテット 第5オクテット 第6オクテット

OUI

ベンダー管理番号



ネットワークモデル

パケットアドレス



●IPアドレス (Internet Protocol Address)

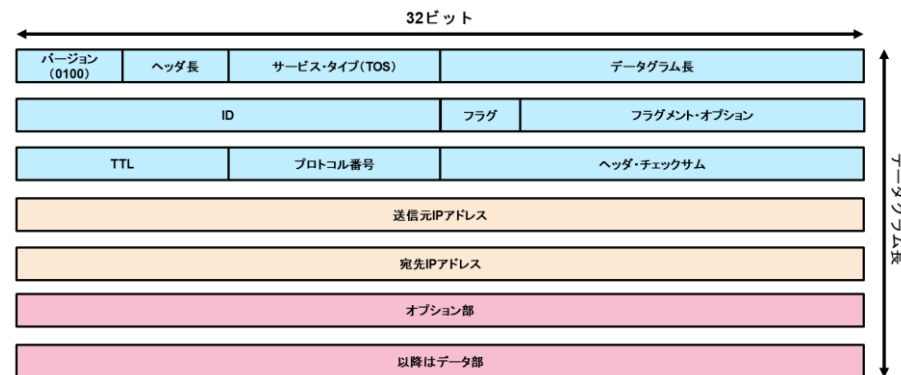
IPv4 (Internet Protocol Address version 4)

- 1970年代に米国国防高等研究計画局 (DARPA) のパケット交換ネットワークをサポートするために設計されました。 IPv4はARPAnetに使用され、後にインターネットに発展しました。

IPv6 (Internet Protocol Address version 6)

- IPv4のアドレス枯渇問題により設計され、実質アドレス枯渇を解消しています。
- IPv6はMACアドレスよりも多くのアドレスを扱えるため、MACアドレスからIP用のアドレスを生成する技術オートコンフィグレーションを持ち、製品製造時点で発番されたアドレスを参考とするため、矛盾なく不要な設計が必要がありません。

ネットワーク インターフェース層		インターネット層		トランスポート層		アプリケーション層
MACアドレス		IPアドレス		ポート番号		データ
宛先	送信元	宛先	送信元	宛先	送信元	



IPv4のパケットフォーマット



IPv6のパケットフォーマット



ネットワークモデル

パケットアドレス

●ポート番号

TCP/IPにおいて、トランスポート層のプロトコルで用いられる、0から65535までの番号が付与された情報の送受信口です。

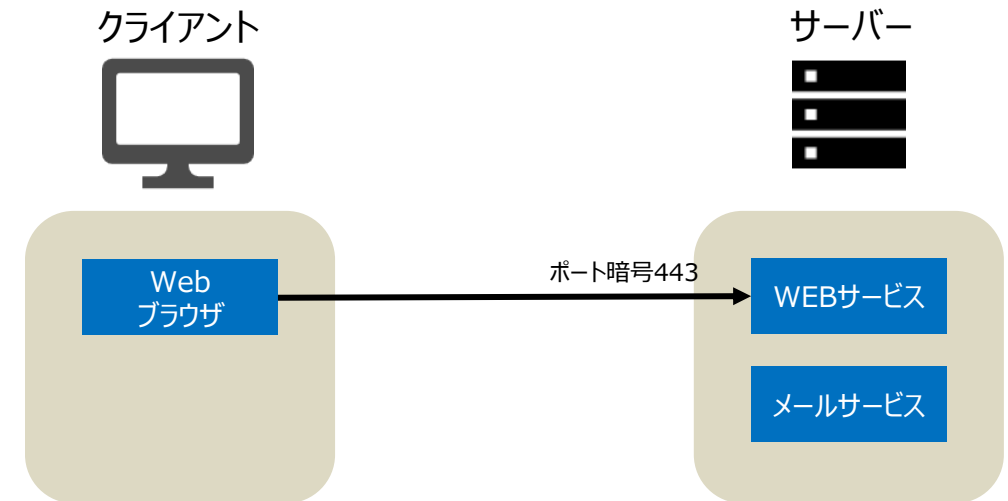
番号区分と意味

- ウェルノウンポート番号 (0-1023)とは、IANAで正式に登録されているポート番号です。
- 登録済みポート番号 (1024-49151)とは、IANAで正式に登録されているポート番号です。
- 動的・プライベート ポート番号 (49152-65535)とは、IANAで正式に登録されていないポート番号です。

●ソケットペア

IPアドレスとTCPまたはUDPポートの組み合わせのことです。サーバー運用で、通信の確立状態を確認することがありますが、ソケットの「リッスン」とは、接続を待機している状態です。「確立」とは、接続している状態です。

ネットワーク インターフェース層		インターネット層		トランスポート層		アプリケーション層
MACアドレス		IPアドレス		ポート番号		データ
宛先	送信元	宛先	送信元	宛先	送信元	



ポート番とサービス利用



ネットワークモデル

パケットアドレス

●IPアドレスのクラス化（RFC1918）

クラスフルネットワーク

- IPアドレスは、ネットワーク規模に合わせて利用するIPアドレスを指定されています。
- それぞれのクラスに対してプライベートアドレスも決められており、内部ネットワークに利用します。
- クラスA、クラスB、クラスCは、ネットワークのホストに割り当てます。
- クラスDは、IPマルチキャスト用のIPアドレスです。マルチキャストグループアドレスを表しています。
- クラスEは、実験的な目的のために予約されたものであり、実際に使われることはありません。

クラス	先頭ビット列	アドレス範囲	割り当て可能ホスト数	プライベートアドレス
クラスA	0	0.0.0.0～127.255.255.255	16777214個	10.0.0.0/8
クラスB	10	128.0.0.0～191.255.255.255	65534個	172.16.0.0/16
クラスC	110	192.0.0.0～223.255.255.255	254個	192.168.0.0/24
クラスD	1110	224.0.0.0～239.255.255.255	-	-
クラスE	1111	240.0.0.0～255.255.255.255	-	-

ネットワークモデル

パケットアドレス



●IPアドレスのクラス化（RFC1918）

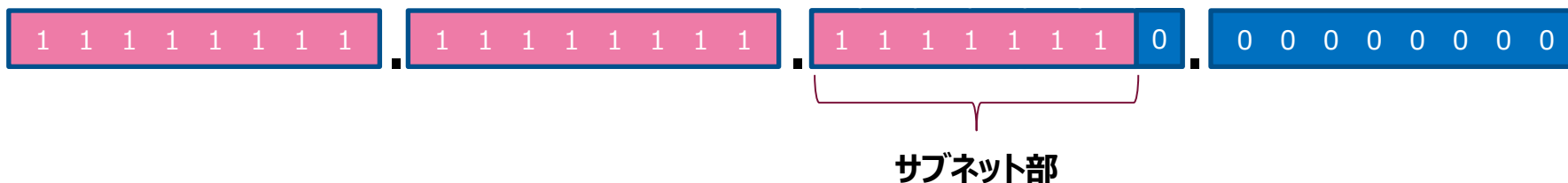
クラスレスネットワーク

- CIDR（Classless Inter-Domain Routing）とは、ホスト部のビットの一部をネットワーク部にすることでより多くのネットワークを構成することが可能にするため、クラスフルネットワークにサブネットで細分化する方法です。
- クラスフルネットワークでは、実際ネットワークの数は限られているため、ネットワークの区分ルールをベースとして自ネットワークを構成する目的です。

クラスBのネットワークマスク（255.255.0.0）



クラスBのネットワークマスク（255.255.0.0）をサブネットで細分化



ネットワークモデル

パケットアドレス

●ユニキャスト、マルチキャスト、ブロードキャスト

通信のアドレスは、番号によっては送付先を複製する意味合いを持ちます。

ユニキャスト

- 1対1で行われるデータ通信です。
- 最も一般的でWebサイトを見るときにはユニキャスト通信でコンテンツが閲覧できています。

マルチキャスト

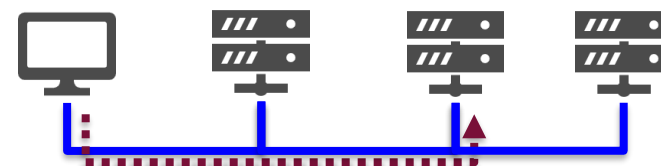
- 1対複数で行われるデータ通信です。マルチキャストなら、一度に同時に宛先の数だけそのパケットを送信することができる。
- マルチキャストアドレスというクラスDのIPアドレスを利用します。
- グループに所属する全てのPCにデータを送る通信方式であり、動画配信などでよく使用されます。

ブロードキャスト

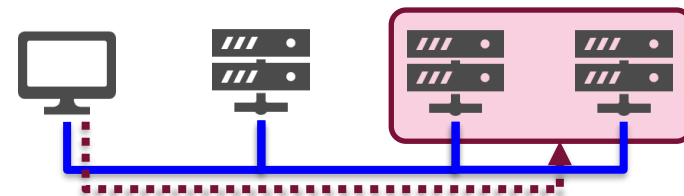
- 同じLAN内の全宛先に対して行われるデータ通信です。
- サービス用途では使われず、LAN内の端末の情報取得などのシステム管理で利用します。特定のIPアドレスやMACアドレスがどの端末にいるかわからないとき、ブロードキャストで聞き、その応答にこたえられる機器がユニキャストで応答する形式がとられます。



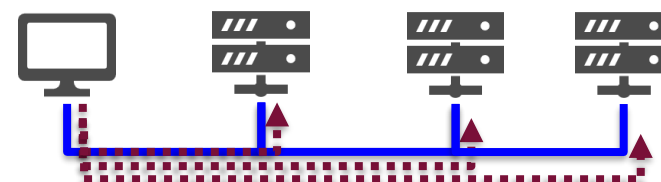
ユニキャスト



マルチキャスト



ブロードキャスト





ネットワークモデル

アドレス変換

● ネットワークアドレス変換（NAT、Network Address Translation）

IPアドレスを変換するための仕組みです。RFC1918アドレスがイントラネットからインターネットに渡される際に、それらを変換するために使用されます。

静的NAT

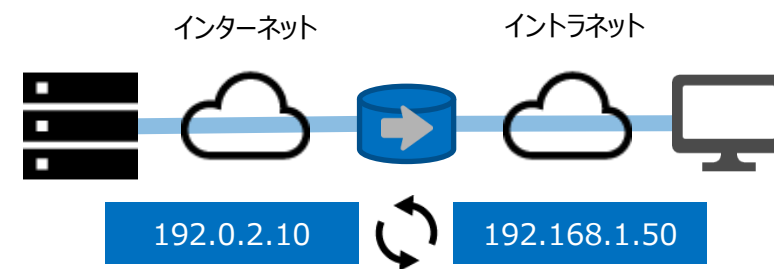
- プライベートアドレスとパブリックアドレスを1対1の変換を行います。

動的NAT

- パブリックアドレスをいくつかプールしておき、利用する際に適宜割り当てられます。

ポートアドレス変換（PAT、Port Address Translation）

- 複数のプライベートアドレスから1つのパブリックアドレスに変換します。
- PATは利用しているプライベートアドレスとサービスポートの組み合わせとパブリックアドレスをキャッシュします。



NATの役割

表：ネットワークアドレス変換

NATの種類	例
静的NAT	192.168.1.50 → 192.0.2.10
動的NAT	192.168.1.50 → 192.0.2.10 192.168.1.55 → 192.0.2.11 192.168.1.57 → 192.0.2.12
PAT	192.168.1.* → 192.0.2.10

ネットワークモデル

アドレス変換

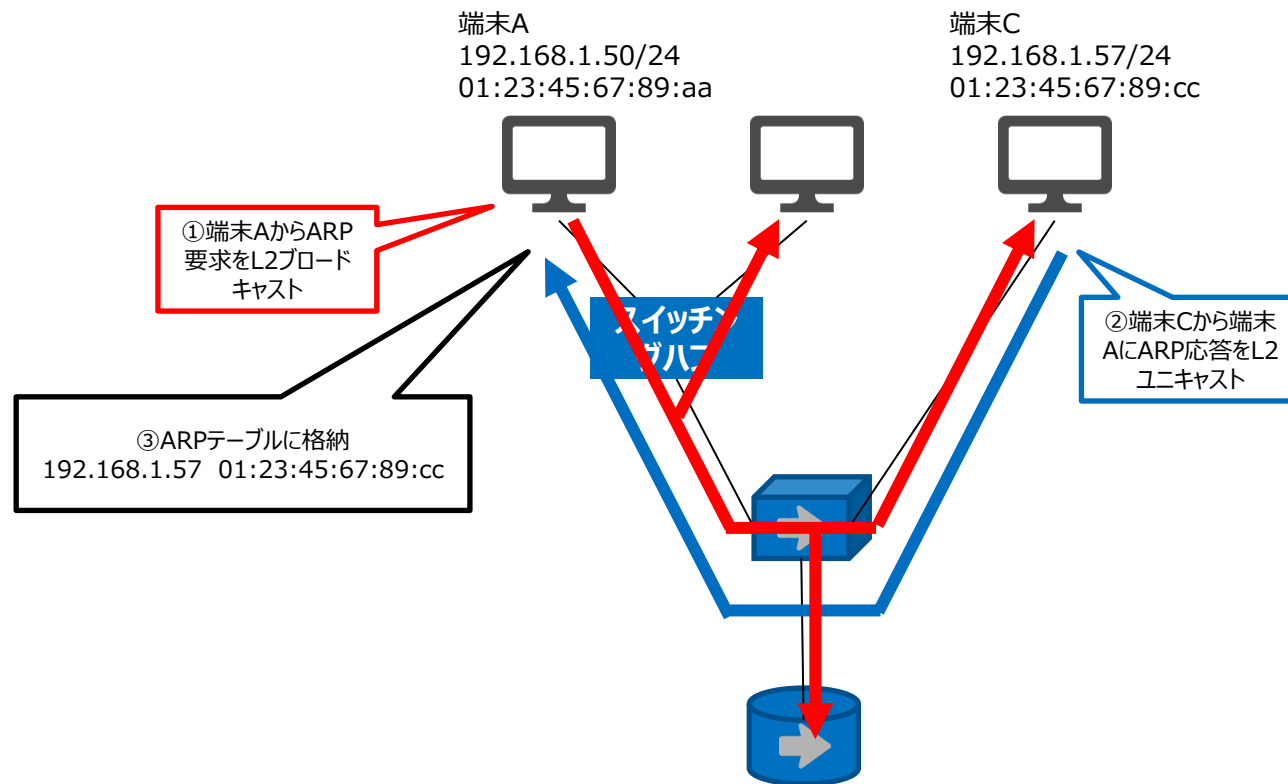


● ARP (Address Resolution Protocol) 、RARP (Reverse Address Resolution Protocol)

ARPは、レイヤー2のMACアドレスとレイヤー3のIPアドレスの間の変換するためのアドレス解決プロトコルです。

ARP要求をL2ブロードキャストを行い、同一ネットワーク上の端末を行います。該当の端末は、ユニキャストでARP応答を行います。これにより、IPアドレスとMACアドレスを紐づけることができ、端末はテーブルに格納することで、今後のARP要求を省略します。

逆にMACアドレスからIPアドレスを答えるプロトコルをRARPと呼びます。



ARPによるIPアドレスとのマッピング



ネットワークモデル

ICMP/UDP/TCP

● リクエストとレスポンス

通信は、要求と応答から成ります。外部端末に対して情報を取得や更新などを処理を要求/リクエストと、受け取り側で得られた処理結果を返却する応答/レスポンスから成ります。

応答は、セキュリティとして返却しない（受け取り手側で破棄）場合もあるが、基本的には正常ではない場合も含め何かしらの応答を返却します。そのため、要求と応答は1対1になり、このペアの通信が完了していないにも関わらず新しい通信を前提とすることはありません。

● ICMP (Internet Control Message Protocol)

レイヤー 3 の通信プロトコルです。シーケンス制御のかからないサービスによらない通信を行うことが可能です。

サービスのために使われる事はあまりないが、トラブルシューティングの時には有効です。接続ダウン時に、どのサーバもしくはルータが落ちているのかを特定することが可能です。

実際に利用する際には、「ping」コマンド、「traceroute」コマンドを使います。

● UDP (User Datagram Protocol)

TCPと比べシンプルなレイヤー 4 の通信プロトコルであります。

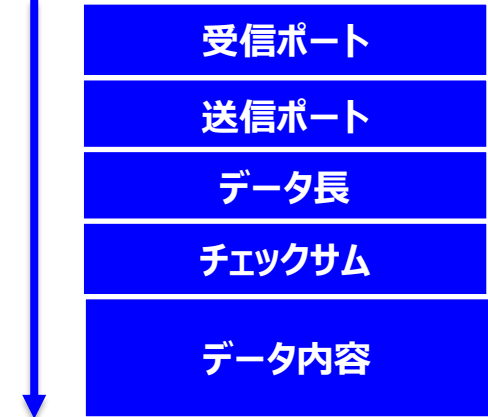
送信完了の有無を確認するすべはなく、送信してもその通信が相手に届いていることを保証しません。

TCPと比べ高速であるため、劣化しても良いデータ音楽のストリーミング、DNS通信等に利用されます。

ICMPの packets 構造



UDPの packets 構造





ネットワークモデル

ICMP/UDP/TCP

●TCP (Transmission Control Protocol)

信頼性のあるレイヤ4通信を担保するためのプロトコルです。

TCPスリーウェイハンドシェイクを使用して、ネットワーク全体に信頼性の高い接続を作成します。

TCP接続した場合、分散して到着したセグメントを並べ替えたり、欠落しているセグメントを再送信できます。

TCPフラグ

- 各TCPパケットのTCPヘッダ内の6ビットのフィールドであり、パケット内容を示します。

TCPのパケット構造

受信ポート
送信ポート
シーケンス番号
確認応答番号
データオフセット
予約済み
フラグ
ウィンドウ
チェックサム
緊急ポインター
オプション
パディング
データ内容

フラグ	意味
URG	パケットに緊急データが含まれている
ACK	受信データを確認
PSH	アプリケーションレイヤーにデータをプッシュ
RST	接続をリセット（破棄）
SYN	接続を同期
FIN	正常に接続を終了
CWR	輻輳ウィンドウ削減
ECE	明示的な輻輳通知エコー
NS	輻輳を管理

ネットワークモデル

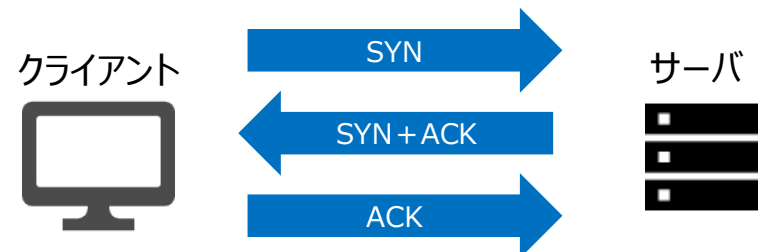
ICMP/UDP/TCP

●TCP (Transmission Control Protocol)

TCPスリーウェイハンドシェイク

- SYN、SYN-ACK、ACKの3つのステップで実行される。
- ① クライアントがランダムに決めたシーケンス番号を付与したSYNパケットを送る。
- ② サーバは受け取ったシーケンス番号と1を加えたACK番号を付与したSYN+ACKパケットを返信する。
- ③ クライアントが受け取ったシーケンス番号に1を加えたものとACK番号を付与したACKパケットを送信することで接続の確立する。
- 確立された接続は、最終的にRST（接続をリセットまたは切断）またはFIN（接続を正常に終了）で終了します。

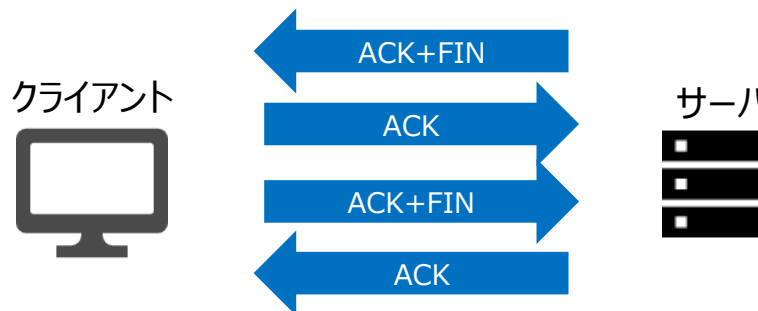
スリーウェイハンドシェイク



コネクションの確立



コネクションの切断





ネットワークデバイス

関連用語

- ケーブルカテゴリ
- イーサネットの種類
- 無線の種類
- ツイストペアケーブル
- 同軸ネットワークケーブル
- 光ファイバネットワークケーブル
- イーサネット
- CSMA/CD (Carrier Sense Multiple Access with Collision Detection)
- リピーター
- ハブ
- ブリッジ
- ファイヤーウォール
- ステートフルインスペクション
- アプリケーションレベルゲートウェイ
- 携帯情報端末 (PDAS)

ネットワークデバイス

ケーブル



●通信ケーブルの目的

ケーブルは物理的現象に対して欠損なく、高速に伝送することを目的とする。なおかつ、非常に多く利用されるものであり、安価であることが市場では望まれます。

●ツイストペアケーブル

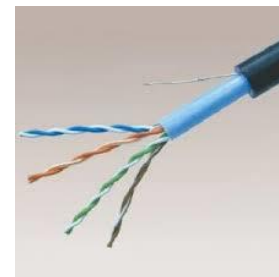
ケーブル内部に送信用と受信用の電気を送る2本のワイヤーを一緒にねじる事で電磁干渉を弱まります。

●同軸ネットワークケーブル

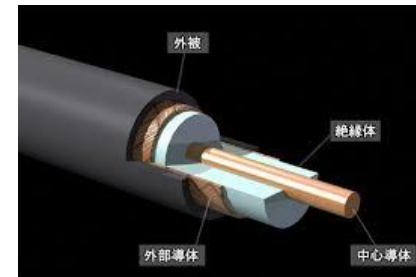
金属製のシールドから絶縁体で分離された内部銅コアがあり、外層はプラスチックである。絶縁体は、コアが金属シールドに接触するのを防ぎます。

同軸ネットワークケーブルは、衛星およびケーブルTVサービスによく使用されます。

同軸ケーブルの電磁干渉（EMI、Electro-Magnetic Interference）に対する耐性が高まり、ツイストペアケーブルと比較して、より高い帯域幅とより長い接続が可能になります。



ツイストペアケーブル



同軸ネットワークケーブル

ツイストペアケーブル規格

カテゴリー	スピード (Mbps)	利用ケース
Cat 1	<1	アナログ音声
Cat 2	4	ARCNET
Cat 3	10	10baseT イーサネット
Cat 4	16	トークンリング
Cat 5	100	100baseT イーサネット
Cat 5e	1000	1000baseT イーサネット
Cat 6	1000	1000baseT イーサネット

ネットワークデバイス

ケーブル

● 光ファイバネットワークケーブル

ファイバの利点は、速度、距離、およびEMIに対する耐性です。欠点には、コストと複雑さです。膨大な量の情報を伝送でき、ツイストペアや同軸などの銅ケーブルよりもはるかに遠い長距離の伝送に使用できます。

シングルモードファイバ

- 一度に1つのタイプの光モードを伝播させることを意味します。
- シングルモードファイバーでは、コアの直径を細くすることで1つのモードだけが通るため、長い距離を伝送しても信号がひずみが生じにくい特徴があります。

マルチモードファイバ

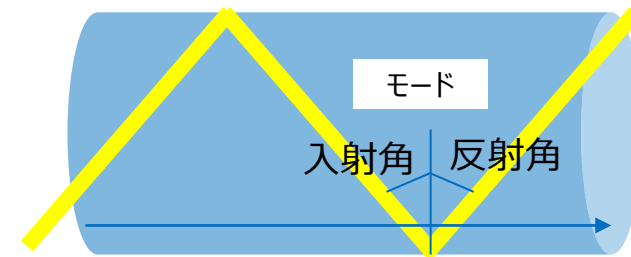
- 光の複数のモード（パス）を使用します。マルチモードファイバはコアの直径が太いため、複数のモード（経路）が生じ、同じ信号でも受信側に届く時間がずれ、信号がひずみが生じやすい特徴があります。光ファイバが長いほど大きくなるため、長距離に向きません。

多重シグナル

- 波長分割多重（WDM、Wavelength Division Multiplexing）を使用して同じファイバーを介して伝送します。



光ファイバネットワークケーブル



光モードと入射角

ネットワークデバイス

ケーブル

●イーサネット

ネットワークデータを送信する主要なローカルエリアネットワークの技術です。

衝突

- 2つの端末が同時にデータを送信したときに、同じケーブル内を利用するため、物理的に衝突を制御する必要があります。



イーサネットの規格

イーサネット名	タイプ	速度[メガビット]	最大距離[m]
10Base2 'Thinnet'	バス	10	185
10Base5 'Thicknet'	バス	10	500
10BaseT	スター	10	100
100BaseT	スター	100	100
1000BaseT	スター	1000	100

ネットワークデバイス

ケーブル

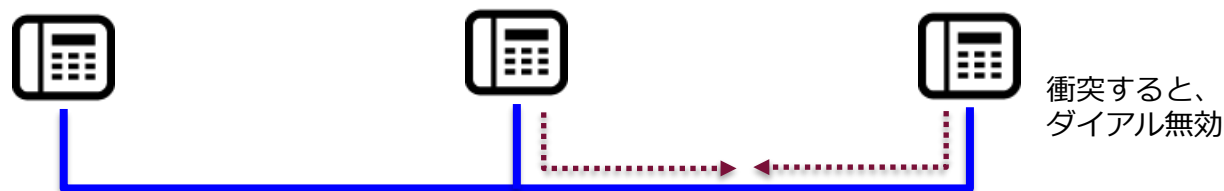
●イーサネット

CSMA/CDとは、この衝突を回避できる仕組みです。1本のケーブル上（1つのネットワークの媒体上）を複数のノードがお互いにアクセス（Multiple Access）できるようになります。

ARCNET（Attached Resource Computer Network）/トークンリング

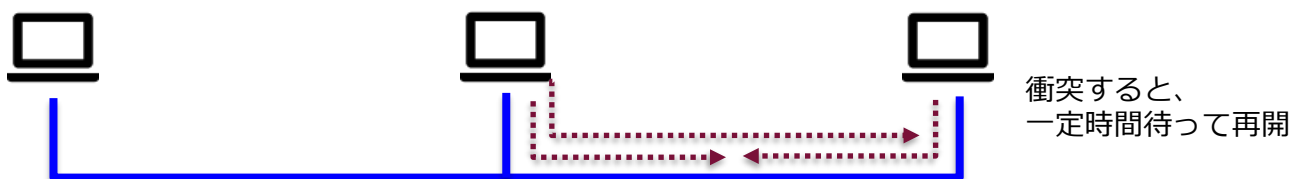
- 端末からネットワークに回線を占有するためのトークンを伝送します。
- トークンをキャッチすると、端末はネットワーク上のトラフィックを読み書きできます。

従来の電話回線通信プロセス



- ① 受話器を持ち上げると、回線がアイドル状態かどうかを確認
- ② 回線がアイドル状態でない場合は、電話を切り、再試行するまで待機
- ③ 回線がアイドル状態の場合は、ダイヤル実行
- ④ 同時に受話器を持ち上げると両方でアイドル状態と判定され、衝突が起こると、ダイヤルは無意味となる。

CSMA/CDの衝突回避プロセス



- ① イーサネットフレームを送りたいPC端末はケーブルの通信状況（電気信号の状況）を確認します。
- ② フレームが伝送されていなければ自身のフレームを送信します。
- ③ 複数の機器が同時に送信してデータが衝突する場合、ある時間を待って送信をやり直します。
- ④ 信号を感知（Carrier Sense）しフレーム伝送を行い、フレームが衝突を検出（Collision Detection）するとランダムな時間を待ち送信を開始します。

ネットワークデバイス

中継機器

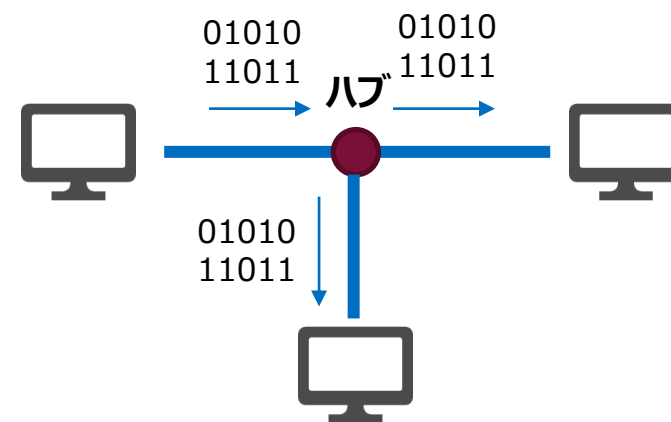
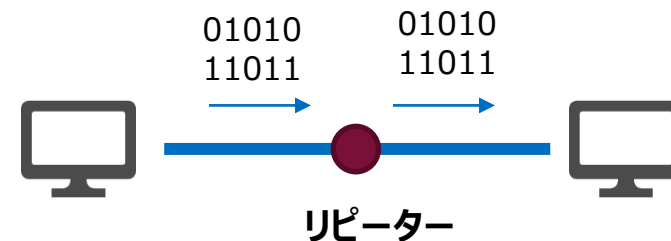
●レイヤー1のデバイス

リピーター

- ある一方のポートでビットを受信し、もう一方のポートでビットを繰り返します。
- ネットワークケーブルの長さが足りない場合に利用されます。

ハブ

- 1つのポートでビットを受信し、他のすべてのポートでビットを繰り返します。
- ハブはネットワークトラフィックの機密性がないため、実運用で利用されることはありません。フォレンジックを調査といったトラフィックを調査する目的で利用されます。



ネットワークデバイス

中継機器

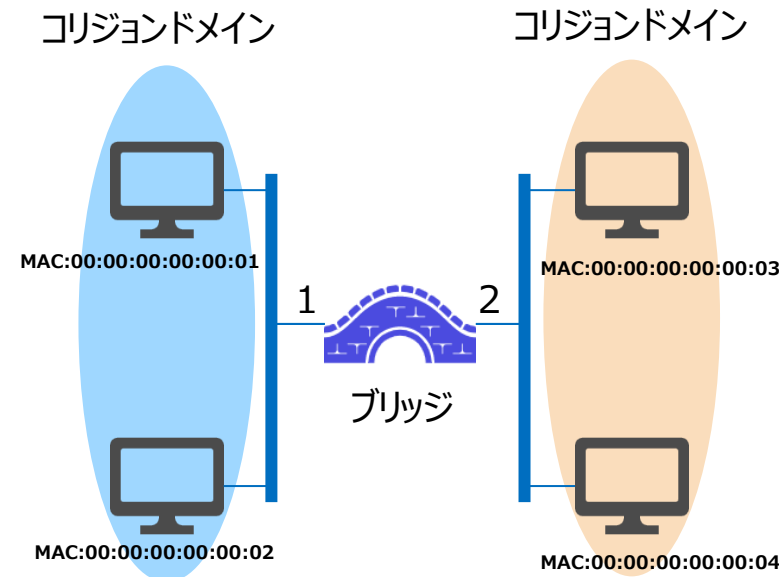
●レイヤー2のデバイス

ブリッジ

- 複数のネットワークセグメントを結ぶ中継機器のうち、受信したデータのMACアドレスを参照して中継のするかを判断する。接続されたセグメントから流れてきたデータの宛先情報が、もう一方のセグメントに向けのものであれば中継し、そうでないものは破棄します。
- 無駄な信号が流れるのを防いで性能を向上させることができます。
- ネットワークセグメントのことを**コリジョンドメイン**と呼びます。同じコリジョンドメインある端末同士は、スニファできるが、ブリッジを介した端末に対してはできません。

スイッチ

- 3つ以上のポートを持つブリッジです。
- ポートを複数持つため、スイッチポートごとに1つのデバイスのみを接続することが推奨されます。



1 MAC:00:00:00:00:00:01
1 MAC:00:00:00:00:00:02
2 MAC:00:00:00:00:00:03
2 MAC:00:00:00:00:00:04

ネットワークデバイス

中継機器

●レイヤー2のデバイス

仮想LAN (VLAN、Virtual LAN)

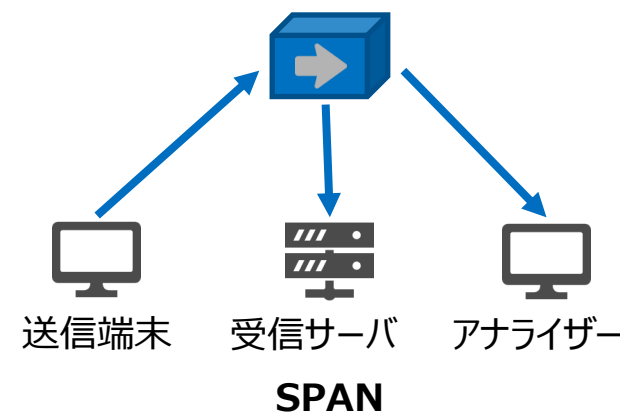
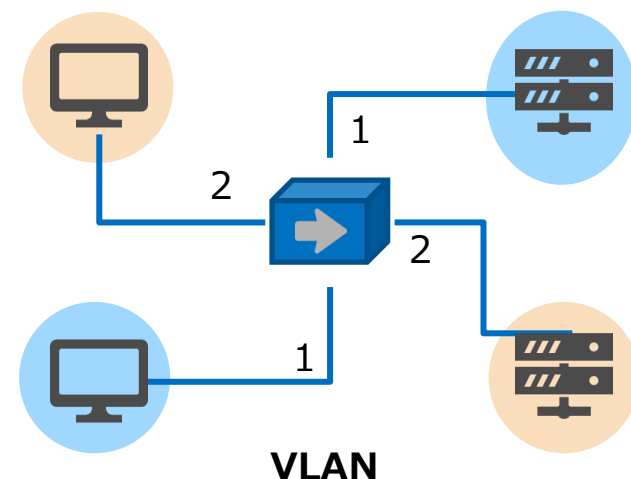
- スイッチのポートを仮想的（ソフトウェアによって）に区分し、コリジョンドメインを分ける技術です。ポートの物理的位置は隣接している必要がありません。

プライベートVLAN (PVLAN、Private LAN)

- 1つのVLANであっても分割するプライベートVLANという技術がある、1つのVLAN内でブロードキャストを分割でき、同じサブネットでありながらセキュリティが確保できます。
- それぞれのポートをプライベートVLAN、セカンダリVLAN（隔離VLAN、コミュニティVLAN）いずれかに属します。
- プライベートVLANはすべてのポートに通信可能、隔離VLANはプライベートVLANとのみ通信可能、コミュニティVLANは同じコミュニティポート番号を振られた端末を通信可能という組み分けを行います。

SPAN (Switched Port ANalyzer)

- スイッチの特定のポートで送受信したフレームを他のポートへ転送（コピー）を行う技術です。
- SPANを利用することで、スイッチを通過するトラフィックをネットワークアナライザを用いて解析することができます。このことをパケットキャプチャとも呼びます。



ネットワークデバイス

中継機器



●レイヤー3のデバイス

ルーター

- 2つ以上の異なるネットワーク間に中継する通信機器です。

●ルーティングプロトコル

静的ルーティング

- ルーティング経路を宛先と次の遷移するルーターを事前に登録（ルーティングテーブルに記録）しておく方法です。
- しかし、一部の機器が故障した場合、その時点でパケットを伝送できなくなり、手動で変更するまで通信障害となります。

ディスタンスベクタールーティングプロトコル（distance-vector routing protocol）、RIP

- ルーター間で定期的にルーティングテーブルを交換します。
- ディスタンスベクタールーティングプロトコルとしては、RIP（Routing Information Protocol）が有名です。RIPv1はクラスフルルーティング、RIPv2はクラスレスルーティングを行います。
- RIPは、ホップ数（経由するルータの数）で最大ホップ数は15、16ホップの経路は到達不能なルートとして扱う。定期的（30秒）にテーブル全体を隣接ルータに通知し、障害発生時はトリガードアップデート行い、その経路を封鎖します。
- ルーティングの通知には**ルーティングポイズン**とは、あるルータから来たパケットを送られたルーターに送り返してしまう問題があるため、他のルーターからもらったルート情報は、その情報をくれたルータが参考しないようにメトリック16を付けて、その情報をくれたルータに通知します（**スプリットホライズン**）。

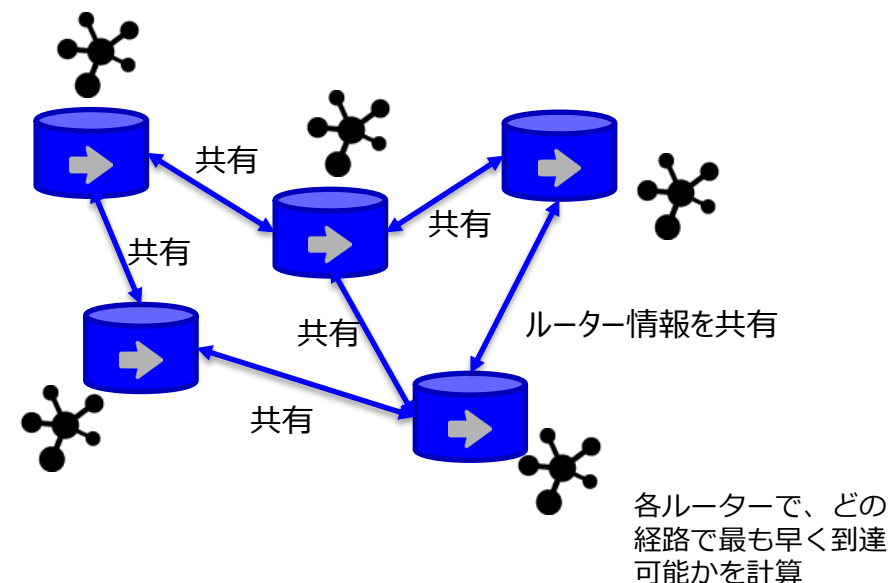
ネットワークデバイス

中継機器

●ルーティングプロトコル

リンクステートルーティングプロトコル (link-state routing protocol)

- リンクステートルーティングプロトコルでは、ポップ制限を持たせない大規模ネットワークに対応したルーティングです。ディスタンスベクタ型ルーティングプロトコルよりも、ルーティングの更新を行う頻度が少なく、即座に最適なルーティングを提供します。
- ディスタンスベクタ型ルーティングプロトコルの場合、自身のルーティングテーブルに隣のルータから通知されたルーティングアップデートの情報をそのまま追加していく方式でしたが、大規模ネットワークにおいてはポップ数15に対応できず、ポップ数の限界を増やしたとしてもルーティングテーブルが大きくなりネットワーク経路変更に伴うアップデートに時間がかかりすぎるため開発されました。
- リンクステートルーティングプロトコルとしては、OSPF (Open Shortest Path First) が有名です。



リンクステートプロトコルの経路計算プロセス

- ① Helloパケットを隣接するルータで交換し、トポロジーテーブルというネットワーク構成を形成します。
- ② トポロジーテーブルに、ルーター情報 (LSA、Link State Advertisement) も格納しておきます。
- ③ その情報からトポロジマップを作成する。
- ④ そのトポロジマップから、SPFアルゴリズムによりSPFツリーと呼ばれるネットワーク構成図を作成し、最短経路を計算します。

ネットワークデバイス

ファイアーウォール

●ファイアーウォール

パケットフィルター

- 最もシンプルな構造のファイアーウォールである。許可する宛先と送信元のペアを事前に登録して置き、各通信の制御を行います。

ステートフル

- 通信のセッション情報を含め制御するファイアーウォールである。リクエストを行った機器からレスポンスのみを受け入れるようにします。

プロキシ

- パケットフィルターとステートフルを両方兼ね備えます。
- プロキシファイアーウォールでは、より最適な制御を行うために通信を中継し、宛先と送信元が直接触れ合う構成をとらなくなり、よりセキュアになります。



パケットフィルターFW



ステートフルFW



プロキシFW



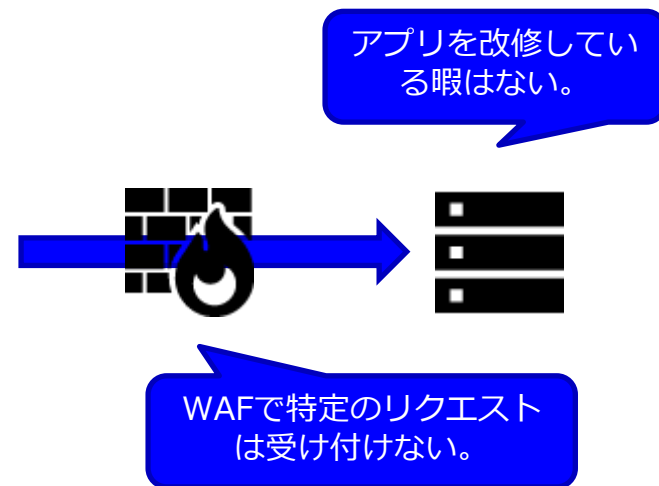
ネットワークデバイス

ファイアーウォール

●ファイアーウォール

アプリケーション

- アプリケーション層でのファイアーウォールである。アプリケーション層のデータ内容まで解釈し、リクエストを転送します。
- 従来型のFWは、宛先と送信元のIPアドレス・ポート番号の組み合わせによるフィルタリングであり、IDS/IPSはOSやミドルウェアなどのプラットフォーム機構を防御する仕組みです。
- アプリケーションにはバッファオーバーフローやSQLインジェクションなど共通する脆弱性があります。アプリケーション自体の通信を制御することで、共通する脆弱性をアプリケーションレベルで解決できます。とりわけ、Web通信に対するアプリケーションレベルゲートウェイのことを**WAF（Web Application Firewall）**といいます。
- アプリケーションの脆弱性は本来アプリケーションのソースコードを改修すべきですが、アプリケーションの一部のモジュールやライブラリに脆弱性が見つかった時、即時に特定個所のソースコードを特定し、全体の機能を損なわないことを確認して公開するにはあまりにも時間がありません。よって、WAFというフィルタリング機能で脆弱性を発現しないようにします。
- WAFは非常に有効ですが、自社で準備するのは容易なことではありません。あらゆる脅威のシグニチャを管理することは自社だけでは難しいため、クラウド機能に頼ることが一般的です。



ネットワークデバイス

ファイアーウォール

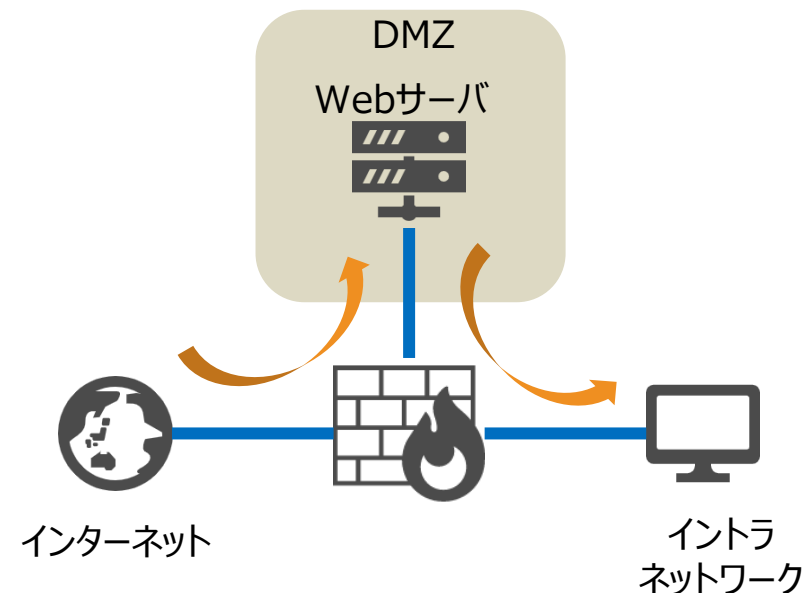
●ファイアーウォールの構成

非武装地域（DMZ、DeMilitarized Zone）

- ・ファイアーウォールは、外の信頼性のないネットワークと内の信頼性を守るべきネットワークを区分するために使います。
- ・アクセス制限はしているものの外部と接触するネットワークを非武装地域DMZと呼ぶ。この領域には、機密性のデータは保持しないことが鉄則です。

シングルファイアウォールDMZ構成

- ・インターネット、DMZ、イントラネットワークをファイアーウォール一つを使って区分する方法です。
- ・インターネットからイントラネットワークにアクセスは拒否し、必ずインターネットとDMZ、DMZとイントラネットワークを経由するように設定します。



シングルファイアウォールDMZ構成



セキュア通信

関連用語

- ポイントトゥポイントプロトコル (PPP)
- 拡張認証プロトコル (EAP)
- IPsec
- SSL/TLS

セキュア通信

認証方式

● リモートアクセス認証方式

ポイントトゥポイントプロトコル (PPP、Point to Point Protocol)

- プロバイダとのアクセスのために、サーバーとパソコン間を結ぶために利用するプロトコルです。
- ダイヤルアップ接続などで使われるプロトコルのPPPには、PAP (Password Authentication Protocol) とCHAP (Challenge Handshake Authentication Protocol) という2種類の認証プロトコルが採用されています。
- PAPはパスワードが平文で流れますが、CHAPはチャレンジ・レスポンス方式を採用して、パスワードそのものを経路上に流しません。

拡張認証プロトコル (EAP、Extensible Authentication Protocol)

- リンクの確立段階では認証方式を特定せず、接続の検証段階でEAPタイプと呼ばれる特定のEAP認証方式を使います。
- EAPタイプはクライアントと認証サーバの両方に認証プラグインモジュールとしてインストールされていればよいため、ベンダーはいつでも新しい認証方式モジュールを追加提供できます。



プロバイダーとの接続

拡張認証プロトコル

認証方式	内容
EAP-MD5	EAPフレームワークにおけるCHAP認証
EAP-TLS	電子証明書を利用したPKI認証を採用
EAP-TTLS	サーバ側は電子証明書、クライアント側ではユーザー名とパスワードを利用
LEAP	シスコシステムズ独自の認証方式

セキュア通信

通信暗号化



● 仮想プライベートネットワーク（VPN、Virtual Private Network）

エクストラネットの実装のように、拠点間を結ぶためにネットワーク層・データリンク層にて、通信の機密性を担保する技術を仮想プライベートネットワークと言います。

インターネットVPN

- インターネット上で作成するVPNです。エントリーVPNに分類される場合もあります。ネットワーク層の通信を仮想化します。IPSecやSSLが一例です。

エントリーVPN

- 事業者網を利用するが、高い回線品質は保証していないVPNです。レイヤー 3 の通信を仮想化します。

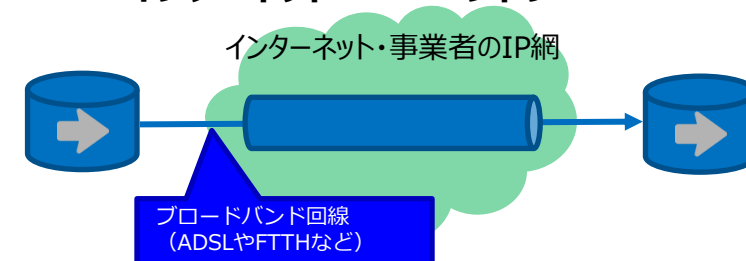
IP-VPN

- 高い回線品質を保証するVPNです。ネットワーク層の通信を仮想化します。

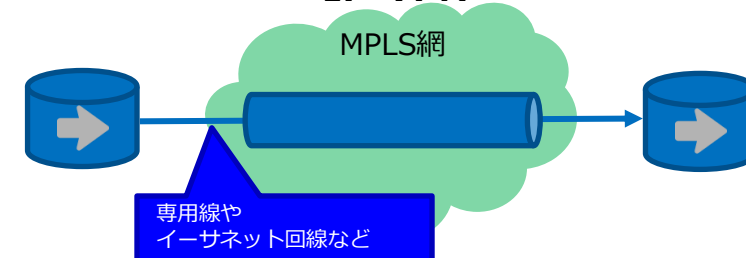
広域イーサネット

- 高い品質を保証しつつ、様々なプロトコルに対応するVPNです。データリンク層の通信を仮想化します。

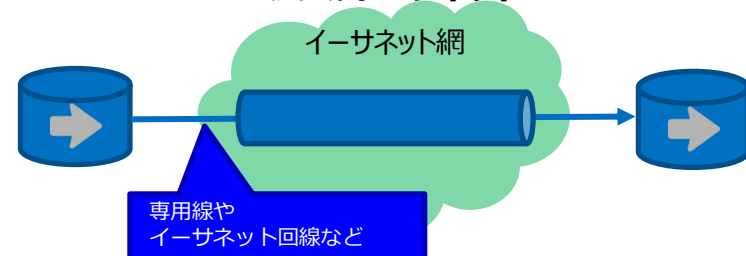
インターネットVPN・エントリーVPN



IP-VPN



広域イーサネット



セキュア通信

通信暗号化

●インターネットVPN

IPsec (Internet Protocol Security)

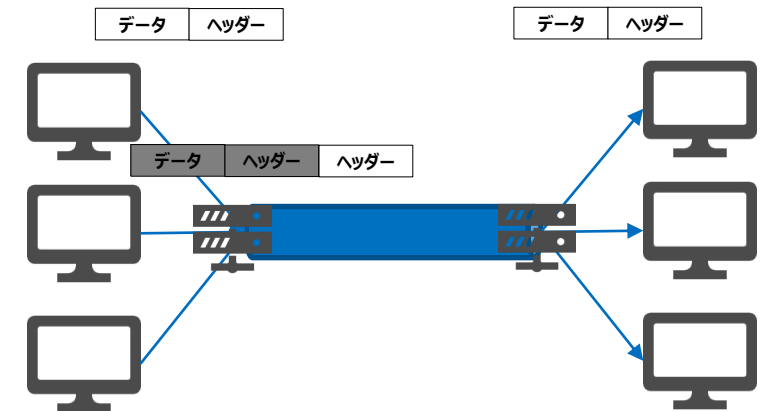
- ネットワーク層で機密性を保護する仕組みです。
- IPsecには、認証と改ざん防止のみを行うAH (Authentication Header) と、データの暗号化を行うESP (Encapsulated Security Payload) が提供されています。
- IPsecを使って通信する際に利用する論理的な通信路SA (Security Association) を確立する際、IKE (Internet Key Exchange protocol) により暗号化のための鍵を交換します。
- データ部分のみを暗号化する**トランスポートモード**とヘッダとデータの両方を暗号化する**トンネルモード**があり、IPsecを用いたインターネットVPNによって複数コンピュータを管理するような拠点間を接続する場合にはトランスポートモードを採用します。



トランスポートモード



トンネルモード



セキュア通信

通信暗号化

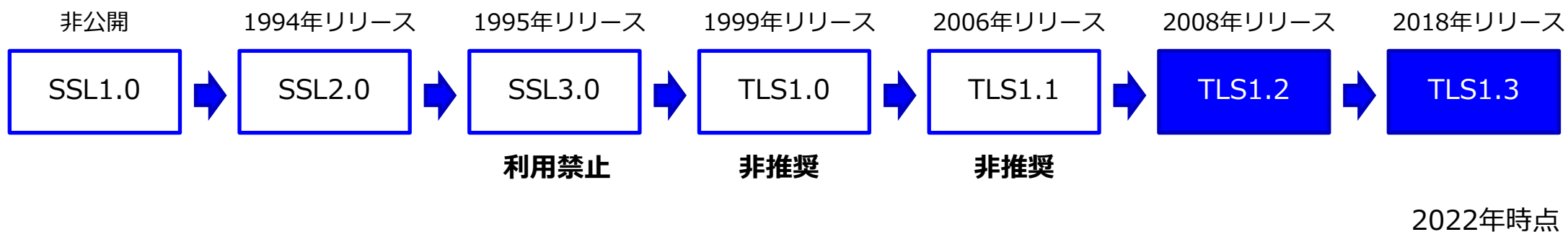


●インターネットVPN

SSL (Secure Sockets Layer) / TLS (Transport Layer Security)

- セッション層において、アプリケーションデータの機密性を保護する仕組みです。SSL/TLSはデータを暗号化し、他のアプリケーションと合わせて利用されます。
- SSL/TLSと他プロトコルの組み合わせにより、そのプロトコルの呼び名、ポート番号が変わります。

通信プロトコル	通信の秘蔵性	ポート番号
HTTP	平文通信	80
HTTPS	暗号通信	443
FTP	平文通信	21
SFTP	暗号通信	22





ネットワークエリア管理

関連用語

- TキャリアとEキャリア
- フレームリレー
- ATM
- マルチプロトコルラベルスイッチング (MPLS)
- 同期データリンク制御手順 (SDLC)
- ハイレベルデータリンク制御手順 (HDLC)
- IP-VPN
- IEEE 802.11
- Bluetooth
- RFID
- FCOE
- iSCSI
- ソフトウェア定義ネットワーク
- コンテンツ配信ネットワーク (CDN)
- ロードバランサー



ネットワークエリア管理

ワイドエリアネットワーク

●Tキャリア、Eキャリア

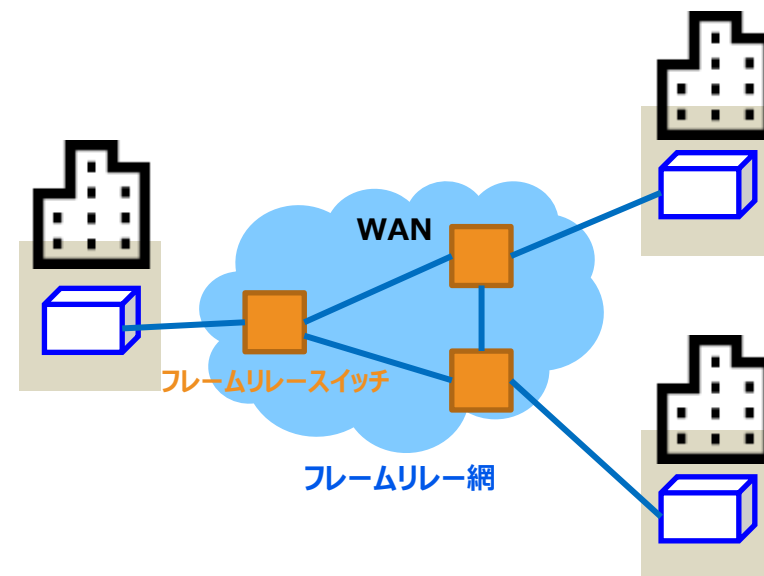
最も普及しているのは、米国のTキャリアと欧州のEキャリアです。
T1、T2、T3というように数が上がるほど多くの回線を束ねて専用線として使うことを意味します。Tキャリアを構成する回線一本一本のことをデジタル回線DSといい、TキャリアはDSキャリアとも呼ばれます。T1は、約1.5Mbpsの速度で通信可能です。
64Kbpsのデジタル回線を24本束ねて多重化し、8Kbpsの制御用信号を加えて1.544Mbpsの通信容量を提供します。

●フレームリレー

通信事業者のパケット交換網を通じて広域通信網を構築することができ、企業の拠点間接続などに用いられます。
相手先とはVC（Virtual Circuit）と呼ばれる仮想回線を確立し、データを一定の大きさに分割したパケット単位で送受信します。一本の物理回線に複数の仮想回線で多重化することができ、複数拠点と同時に通信することが可能です。

●ATM（Asynchronous Transfer Mode）

フレームリレーと同じく1つの物理回線を共有して複数の仮想回線を生成することができます。ATMはフレームリレー同様、現在、企業ネットワークのWANサービスとして、ほぼ使用されていません。



フレームリレーの構成



ネットワークエリア管理

ワイドエリアネットワーク

●同期データリンク制御手順（SDLC、Synchronous Data Link Control）

ポーリングを使用してデータを送信する同期レイヤー2WANプロトコルです。
ポーリングはトークンパッシングに似ており、通信を占有するトークンをネットワーク内に流しトークンをキャッチしたものが通信を占有できる形態です。HDLCはSDLCの後継です。

●ハイレベルデータリンク制御手順（HDLC、High level Data Link Control）

データリンク層（リンク層）の通信規約（プロトコル）の一つです。
相手の応答を待たず連続して送信できるなど伝送効率が高く、CRCによる誤り制御などを行うなど信頼性も確保しています。

項目	HDLC	SDLC
概要	ネットワークポイント間のデータ伝送のためのルールやプロトコルのグループである。	高品質なソフトウェアを作るためのプロセスを明確に定義した方法論のことである。
開発元	ISO	IBM
開発年	2002年	1975年
標準	ISO/IEC 13239	ISO/IEC 12207
パケットサイズ	ビットオクテットの倍数	8、16、32

ネットワークエリア管理

ワイドエリアネットワーク



● IP-VPN

VPNとは、接続するVPNサーバーが設置されているネットワークと同じセグメントに存在するかのように扱うために、カプセル化によってIPパケットなどをトンネリングする技術です。SSL/TLS、SSH、IPsec、PPTP、L2TP、MPLSなどがあります。

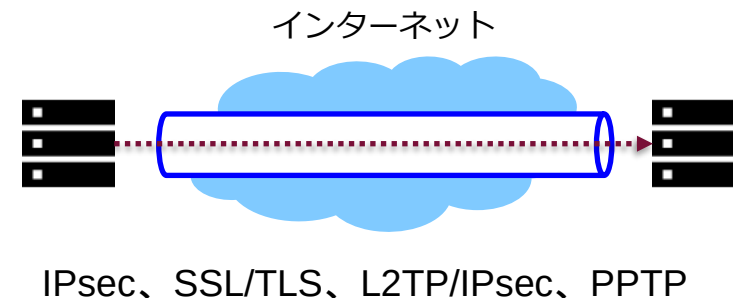
VPNの種類（一部）

- ・ インターネットVPNとは、インターネットを介してVPNを構築するVPNです。
- ・ IP-VPNとは、ISPが提供するIP網（インターネットではない）を利用するIP-VPNです。

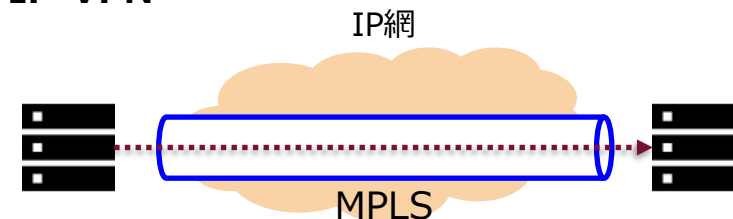
IP-VPN

- ・ IP-VPNでよく利用されるのが、マルチプロトコルラベルスイッチングです。マルチプロトコルラベルスイッチング（MPLS、Multi-Protocol Label Switching）は、ラベルを介してWANデータを転送する方法を提供します。
- ・ MPLSネットワークは、ATM、フレームリレー、IPなどのさまざまなタイプのネットワークトラフィックを伝送できます。転送機能は、ルータの経路選択がIPヘッダの情報を使用するのに対し、MPLSではラベルと呼ばれる識別情報を用いて転送を行います。

インターネットVPN



IP-VPN





ネットワークエリア管理

ワイヤレスネットワーク

●ワイヤレスローカルエリアネットワーク（WLAN、Wireless LAN）

電磁波（ラジオなど）または光を介して情報を送信します。

信頼性の高いネットワークを必要とする重要なアプリケーションでは、主に可用性を理由に有線接続の使用が優先されます。

ISMバンド

- 産業、科学、および医療（ISM）バンドは、ライセンスなしで使用するために確保されており、それらを使用するために、連邦通信委員会（FCC）などの組織からライセンスを取得する必要はない。コードレス電話、Bluetoothなどの多くのワイヤレスデバイスはISMバンドを使用します。
- 国際的に使用されている一般的なISM帯域は、2.4GHzと5GHzです
- 一部のコードレス電話やベビーモニターは、Bluetoothやその他のワイヤレスデバイスと同様に、この周波数を使用するため、2.4 GHzの周波数は非常に混雑する可能性があります。
- 5GHzの周波数は通常混雑が少なく、2.4GHzよりも干渉が少ないことがよくありますが、5 GHzはより短い波で最も高い周波数であるため、より長い2.4GHzの波ほど壁やその他の障害物を透過しません。

表：IEEE 802.11

種類	最大速度	周波数
802.11	2Mbps	2.4GHz
802.11a	54Mbps	5GHz
802.11b	11Mbps	2.4GHz
802.11g	54Mbps	2.4GHz
802.11n	600Mbps	2.4GHz or 5GHz
802.11ac	1.3Gbps	5GHz

IEEE 802.11ワイヤレスには、さまざまな周波数と速度を使用する標準があります。

ネットワークエリア管理

ワイヤレスネットワーク

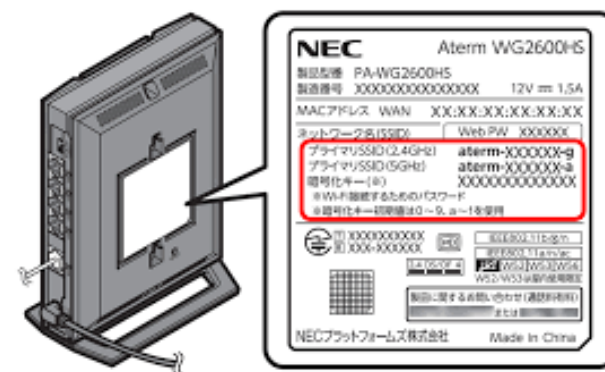


●SSID、MACアドレスフィルタリング

802.11 WLANSは、ネットワーク名として機能するサービスセット識別子（SSID、Service Set Identifier）を使用します。

SSIDは通常ブロードキャストされるため、近くの端末には自分のモバイルWi-FiのSSIDが並びます。セキュリティ機能としてSSIDブロードキャストを無効にするように設定をしているかもしれませんが、不十分なセキュリティ戦略です。SSIDブロードキャストが無効になっている場合でも、モニターモードのワイヤレススニファは、クライアントがWLANに参加するときに使用するSSIDを検出できる。

本当にセキュリティ策を行うのであれば、ワイヤレスMACアドレスをフィルタリングしてクライアントアクセスを制限し、信頼できるクライアントのみを許可することです。MACアドレスは802.11WLANでプレーンテキストで公開される。信頼できるMACが盗聴される可能性があり、攻撃者はソフトウェアで信頼できるMACアドレスを使用して信頼できないデバイスを再構成する可能性がある。攻撃者は、信頼できるデバイスがネットワークを離れるのを待つか、信頼できるデバイスに対してDoS攻撃を仕掛けて停止させ、信頼できるMACアドレスを使用してネットワークに参加できる。



無線LANのSSIDの記載

(https://www.aterm.jp/support/qa/qa_external/00003/wg2600hs.html)

ネットワークエリア管理

ワイヤレスネットワーク



●802.11i

802.11iは、妥当なセキュリティを提供する最初の802.11ワイヤレスセキュリティ規格です。新しい脆弱性が発見されたときに暗号化できるRobust Security Network（RSN）を提供します。RSNは、一般にWPA2（Wi-Fi Protected Access 2）と呼ばれています。WPA2はAES暗号化を使用して、データの整合性を提供するMessage Integrity Check（MIC）を提供します。WPAは、別物で機密性のためにRC4を使用し、整合性のためにTKIPを使用しますが、WPAよりもWPA2の使用をお勧めします。

●Bluetooth

Bluetoothは技術名であり、正確な仕様名はIEEE標準802.15で説明されています。パーソナルエリアネットワーク（PAN）として、多くのタイプの802.11ワイヤレスデバイスと同じ2.4GHz周波数で動作します。携帯電話などの小型の低電力デバイスで使用して、短距離でデータを送信できます。仕様が分かれており、クラス3は10メートル未満、クラス2は10メートル、クラス1は100メートルの通信を提供します。

Bluetoothの脆弱性

- Bluetoothは128ビットE0対称ストリーム暗号を使用しますが、機密性があるわけではありません。機密性の高いデバイスは、他のBluetoothデバイスによる自動検出を無効にする必要があります。
- 検出の「セキュリティ」は、Bluetoothアダプタの48ビットMACアドレスの機密性に依存しており、MACアドレスは2つの番号に構成されており、前半部分が組織、後半部分が端末を示し組織番号は公開されているため、後半部分の端末を示す24ビットを推測することがBluetoothへの攻撃となります。

ネットワークエリア管理

ワイヤレスネットワーク



● マネージド、マスター、アドホック、モニターモード

マネージドモード

- マネージドモードもアクセスポイントになるモードですが、接続した端末同士で通信し合うことができません。

マスターモード

- マスターモードでは接続した端末同士で通信し合うことができます。

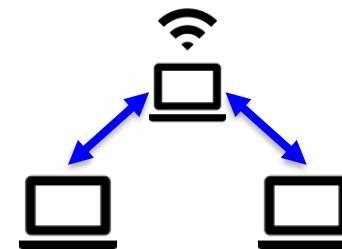
アドホックモード

- マネージドモードとマスターモードのように自身が他の端末と接続する中心のアクセスポイントになるのとは異なり、他の端末と1対1で直接接続するためのモードであります。

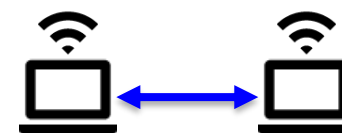
モニターモード

- 読み取り機能のみを提供するものであり、監視などに使われます。

マネージドモード/マスターモード



アドホックモード



モニターモード



ネットワークエリア管理

ワイヤレスネットワーク

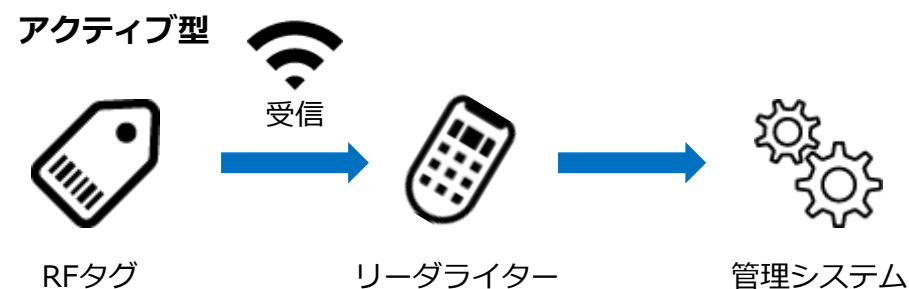
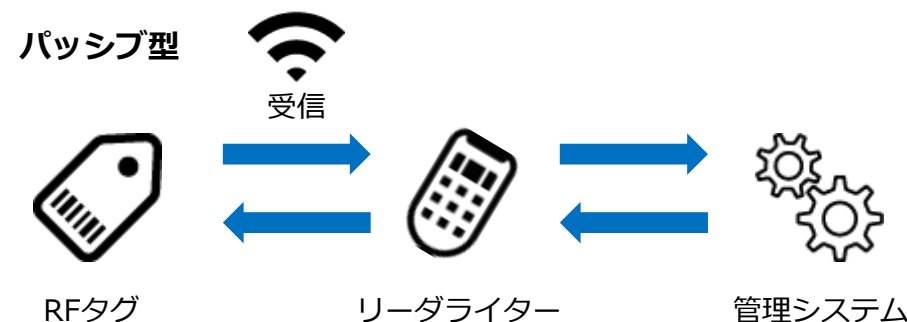


●RFID (Radio Frequency IDentification)

ワイヤレスで読み取り可能なタグを作成するために使用されるテクノロジーです。

RFIDタグの種類

- アクティブおよびセミパッシブRFIDタグは、1～100メートル以上の範囲で信号をブロードキャストするバッテリーアクティブタグです。高速道路の料金の自動支払いを可能にする料金トランスポンダーなどのデバイスは、アクティブなタグを使用します。
- パッシブRFIDタグは、バッテリーが内蔵されておらず、読み取り機リーダーから発信された電波が動力源となり、メモリ内にある情報を発信します。コストは高くないため、倉庫内の在庫の追跡などのアプリケーションに使用されます。



ネットワークエリア管理

ストレージエリアネットワーク



●ストレージプロトコル

FCOE (Fiber Channel over Ethernet)

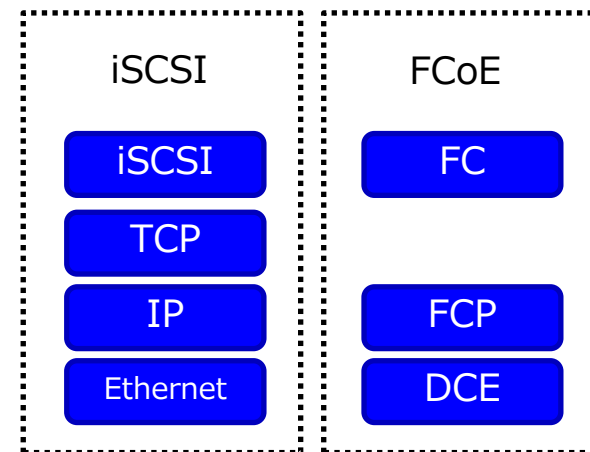
- ファイバチャネルは、フレームをカプセル化してイーサネットで作動作するプロトコルです。
- FCOEによりFC-SANとEthernet LANの統合が可能となります。
- 物理的にはサーバのインターフェースに必要なCNA (Converged Network Adapter) とFCoE対応スイッチが必要です。

iSCSI (Internet Small Computer System Interface)

- 既存のネットワークインフラストラクチャとプロトコルを活用してストレージと接続できるようにするSANプロトコルです。
- FCOEは単にイーサネットを使用しますが、iSCSIは通信にTCP/IPを使用し、他のIPプロトコルと同じように通信できます。
- レイヤー2 (イーサネット) を超えるプロトコルを採用することにより、iSCSIはローカルネットワークだけでなく、WANを介して存在するストレージへのアクセスを許可することもできます。

FCOE vs iSCSI

FCOEによるFC-SANとEthernet LANの統合ネットワークよりも、iSCSIによるIP-SANの方が設計がシンプルと言えます。iSCSIでは、TCP/IPを使用することでオーバーヘッドが発生するため、FCOEのネットワークの方が高いパフォーマンスを発揮します。ただ、それを考慮しても導入しやすさや、移植性点ではiSCSIの方が優勢です。



ネットワークエリア管理

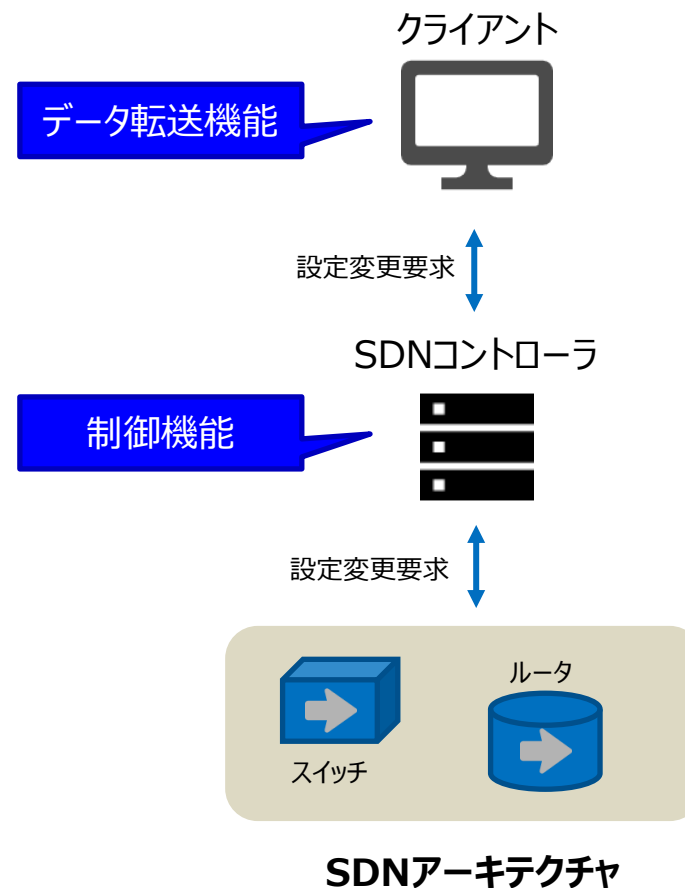
ソフトウェア定義ネットワーク



●ソフトウェア定義ネットワーク（SDN、Software Defined Networking）

ネットワーク機器に対する設定をソフトウェアで制御するものを指します。SDNを使用すると、ルーティングなどの設定は、個々のネットワーク機器ではなく、SDNコントローラを介して、遠隔で行うことができます。これは、ネットワーク機器を集中的に制御できることになり、ネットワーク構成や設定などを動的に変更することができます。

従来のネットワーク機器に設定制御を持たせたネットワークは、サーバやネットワーク機器の追加やネットワーク構成を変更する際に、ルータ、スイッチ、ファイアウォールなどを1つ1つ変更する必要がありましたが、SDNでは機器の「データ転送機能と制御機能」を分離し、制御機能をSDNコントローラに集中管理することで、直接的な変更をすることなく、どの機器にどのような動作をさせるのか設定・管理することができます。



ネットワークエリア管理

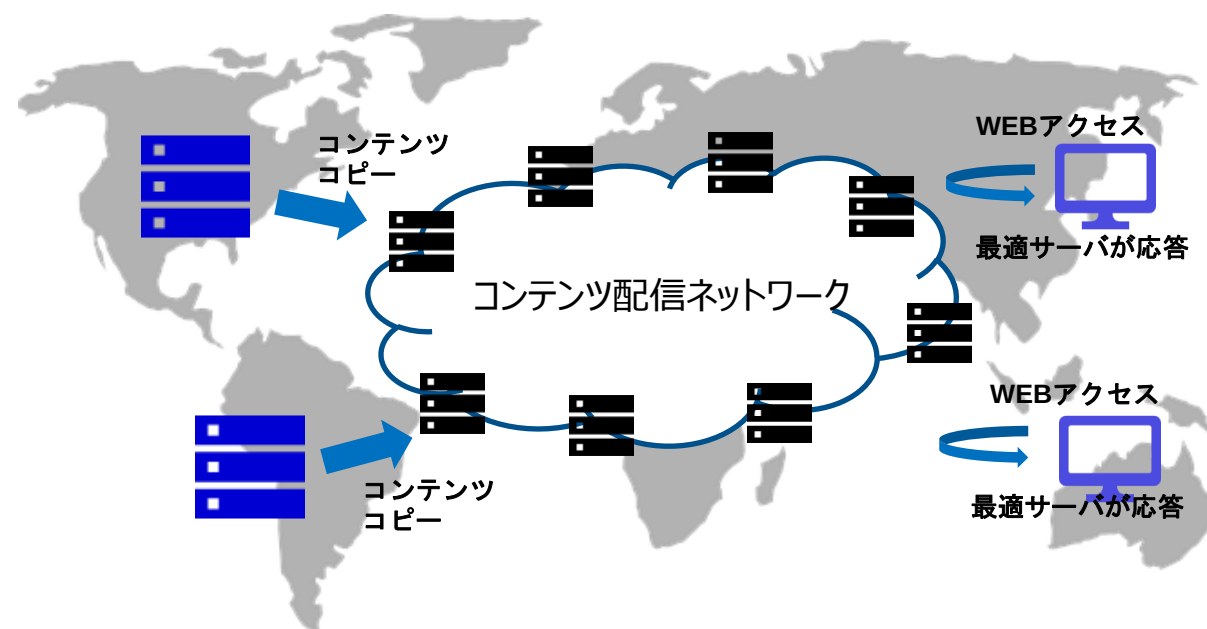
通信流量制御



●コンテンツ配信ネットワーク (CDN、Content Delivery Network)

配信キャッシュサーバーを使用して、パフォーマンスを向上させ、ダウンロードされたオンラインコンテンツの待ち時間を短縮します。エンドユーザーに最も近いサーバーを自動的に決定するため、ユーザーはインターネット上で最も高速で最も近いサーバーからコンテンツをダウンロードします。また、CDNSは可用性を高め、サービス拒否攻撃の影響を減らすこともできます。

例としては、Akamai、Amazon CloudFront、CloudFlare、Microsoft Azureなどがある。



コンテンツ配信ネットワークによるコンテンツ配信の最適化

ネットワークエリア管理

通信流量制御

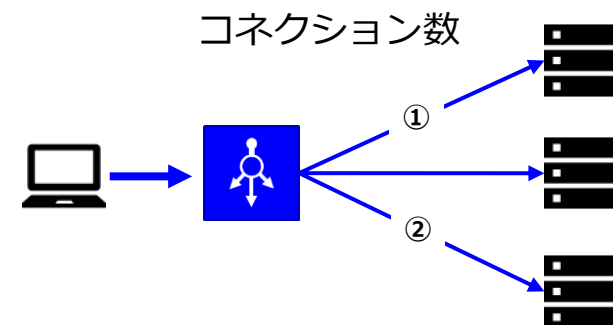
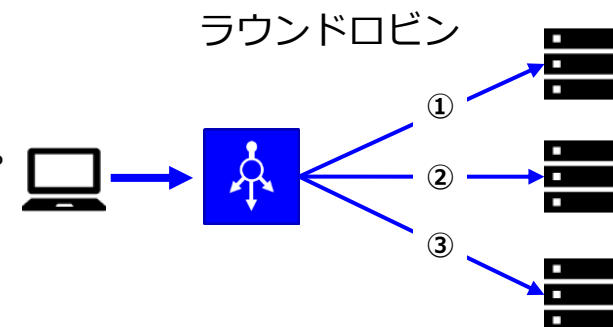
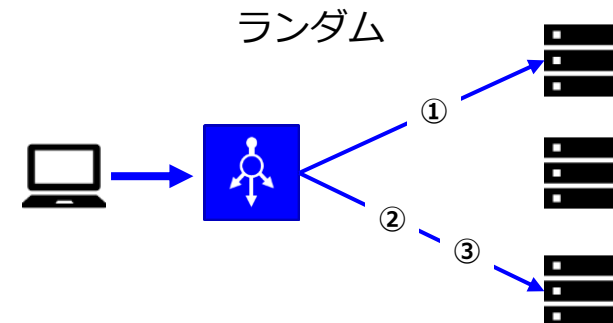
●ロードバランサー

ロードバランサーとは、外部からの通信を複数のサーバーに分散する機構です。負荷分散装置とも呼ばれます。ロードバランシングの目的は、レスポンスタイムを最小化しつつ、システム全体への過負荷を軽減させる事です。

パーシスタンスとは、セッションが続く限りは同じサーバーを利用させるかどうかを決定するものです。ログイン後の処理など順序性のある処理を行うアプリケーションにとって利用されます。

ロードバランスの種類

- “ランダム”とは、各パケットまたは接続は、ランダムに宛先となる処理サーバーを割り当てられます。
- “ラウンドロビン”とは、リクエストを送るサーバーを順々にすることで、負荷が均一になります。
- “重みづけ”とは、サーバー個別の性能差やもしくは性能差が出るようなサーバー環境を意識して重み付けを行います。送られるリクエスト数は重みによって比率を分け、サーバーの負担が均一になるように調整します。
- “コネクション数”とは、サーバー側と張っているコネクションの数に合わせて、次にリクエストを送るかを決めます。
- “地理的な距離”とは、ロードバランサーからの相対的な距離に基づいて宛先を割り当てます。転送先のサーバーが地理的に離れている場合や、多数のルーターにまたがっている場合に使用します。





アプリケーション通信

関連用語

- ウェルノウンポート (well-known port)
- Telnet
- SSH
- FTP
- TFTP
- DNS
- DNSキャッシュポイズニング攻撃
- DNSSEC
- SMTP、POP、IMAP
- SNMP
- HTTP、HTTPS
- BOOTP
- DHCP
- 仮想デスクトップ基盤 (VDI)
- シンクライアント
- ゼロクライアント
- 分散ネットワークプロトコル (DNP3)
- VoIP (Voice over Internet Protocol)
- インスタントメッセージング
- リモート会議テクノロジー

アプリケーション通信

ウェルノウンポート

●Telnet

TCPポート23で実行されるネットワークを介した端末エミュレーションを提供します。

Telnetサーバはユーザー名とパスワードで認証しますが、送信されるすべてのデータは平文であり機密性はありません。

SSH、Secure Shellは、セキュリティ認証、機密性、整合性を提供するため、Telnetの代替品となります。

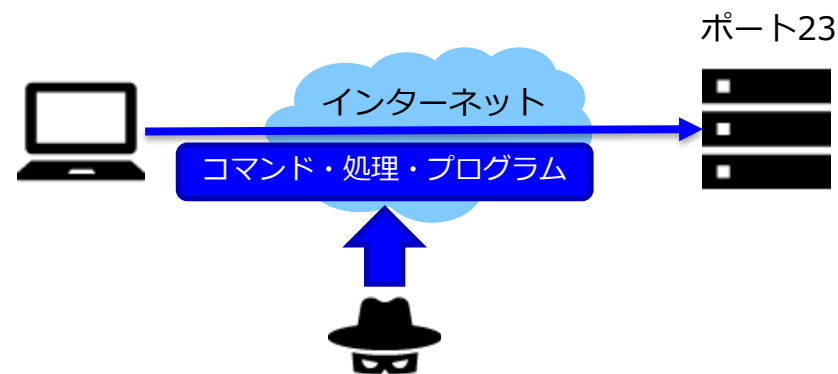
●SSH (Secure Shell)

TCPポート22で実行される安全な端末エミュレーションを提供します。

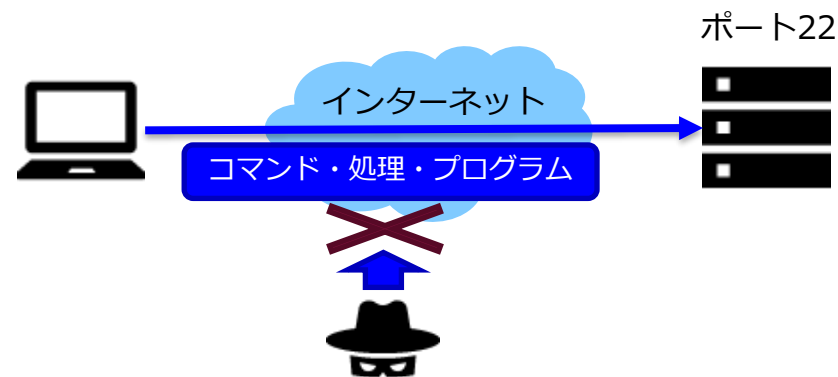
端末に接続するとき、接続端末・ユーザーへの認証として、パスワード認証方式と公開鍵認証方式が用意されています。



Telnetは操作内容を暗号化せずに実行



SSHは操作内容を暗号化して実行



アプリケーション通信

ウェルノウンポート



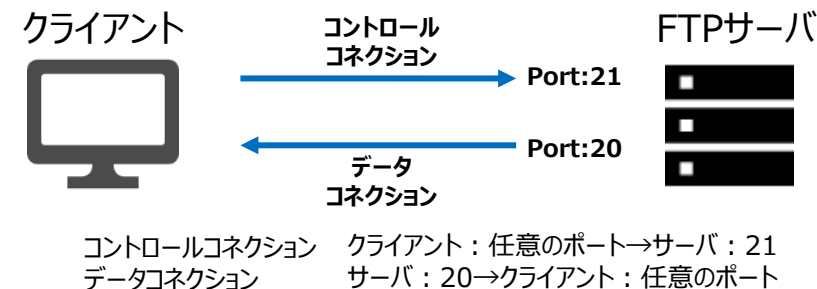
● FTP (File Transfer Protocol)

サーバーとの間でファイルを転送を提供します。機密性や整合性がないため、安全でない通信経路で使用されない。
コントロールコネクションのTCP21ポートと、データを送信するためのデータコネクションのTCP20ポートで実行します。
FTPには2種類の送付方法がある。アクティブFTPでは、アクティブモードを利用するにはクライアント側のFTPポートを開放するため危険です。パッシブFTPによりアクセス方向を一致させる。

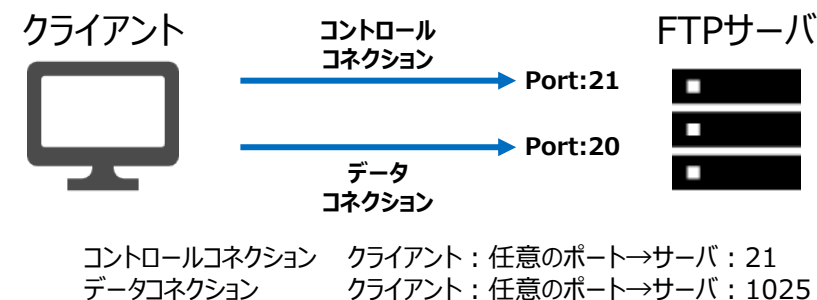
● TFTP (Trivial File Transfer Protocol)

UDPポート69で実行されるファイル転送プロトコルです。TFTPには認証、ディレクトリ構造がありません。機密性や完全性もありません。
ファイル転送するための簡単な方法を提供し、ディスクレスワークステーションによるネットワーク経由でのルーター構成の保存または「ブートストラップ」（オペレーティングシステムのダウンロード）によく使用されます。

アクティブFTP



パッシブFTP



アプリケーション通信

ウェルノウンポート



● DNS (Domain Name Service)

DNSはドメイン名前解決システムです。DNSはTCPとUDPの両方を使用し、ポート番号53を利用します。IPアドレスをドメイン名に変換したり、ドメイン名をIPアドレスに変換する。これを名前解決といいます。

DNS構成サーバ

- DNSキャッシュサーバとは、ドメイン名とIPアドレスの対応の問い合わせを行います。その結果をキャッシュします。
- DNSコンテンツサーバとは、ドメイン名とIPアドレスの対応表を「ゾーン」という単位で管理しており、名前解決を行います。

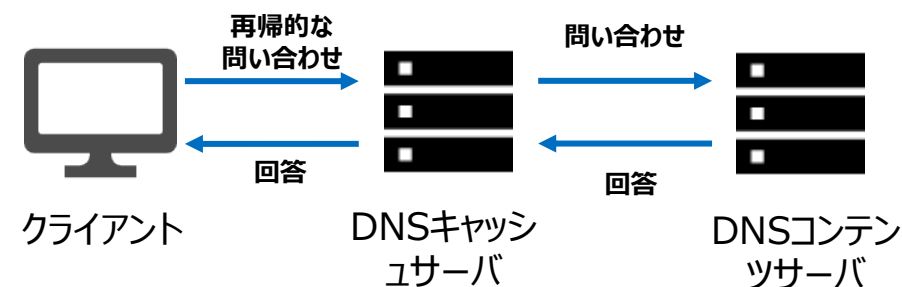
DNSキャッシュポイズニング攻撃

- キャッシュDNSサーバーに偽造された応答をキャッシュさせます。
- 再帰的な問い合わせに対して、DNSキャッシュサーバは自身のキャッシュに名前解決のマッピングリストが存在しない場合、他のDNSコンテンツサーバに問い合わせを行います。
- 問い合わせたDNSコンテンツサーバにもない場合には他のDNSコンテンツサーバに問い合わせます。その間に偽装した回答をDNSキャッシュサーバに返却する。これはDNSがUDPで動作するために偽装しやすい特徴もあります。

DNSSEC (Domain Name System Security Extensions)

- 公開鍵暗号化方式を使用してDNS応答に認証と整合性を提供します。これによりDNSキャッシュポイズニング攻撃は解消される。ただし、DNS応答のデジタル署名のように機能しますが、機密性を提供しません。

DNSアーキテクチャ



アプリケーション通信

ウェルノウンポート



● SMTP、POP、IMAP

SMTP、POP、IMAPはメール配信プロトコルです。

SMTP (Simple Mail Transfer Protocol)

- TCPポート25で実行される、サーバー間で電子メールを転送するためにメール転送プロトコルです。

POP (Post Office Protocol)

- TCPポート110で実行される、クライアントサーバー電子メールアクセスプロトコルです。
- メールは端末に保管されますので、既読・未読・削除、フォルダの分類といった管理は、すべて端末のメールソフト（メーラー）が行います。

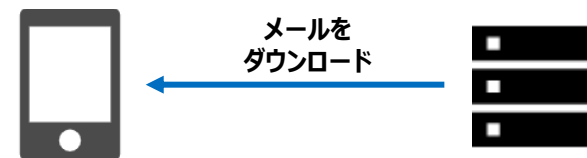
IMAP (Internet Message Access Protocol)

- TCPポート143で実行される、クライアントサーバー電子メールアクセスプロトコルです。
- メールはサーバに保管されますので、既読・未読・削除、フォルダの分類といった管理は、すべてサーバ上で行います。

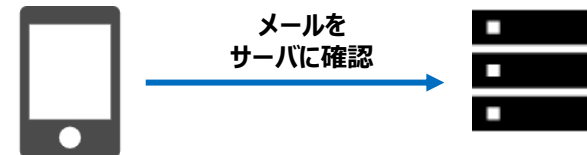
SMTP



POP



IMAP



アプリケーション通信

ウェルノウンポート



● HTTP、HTTPS

HTTP (Hypertext Transfer Protocol)

- TCPポート80を使用し、暗号化されていないWebデータを転送するために使用されるハイパーテキスト転送プロトコルです。

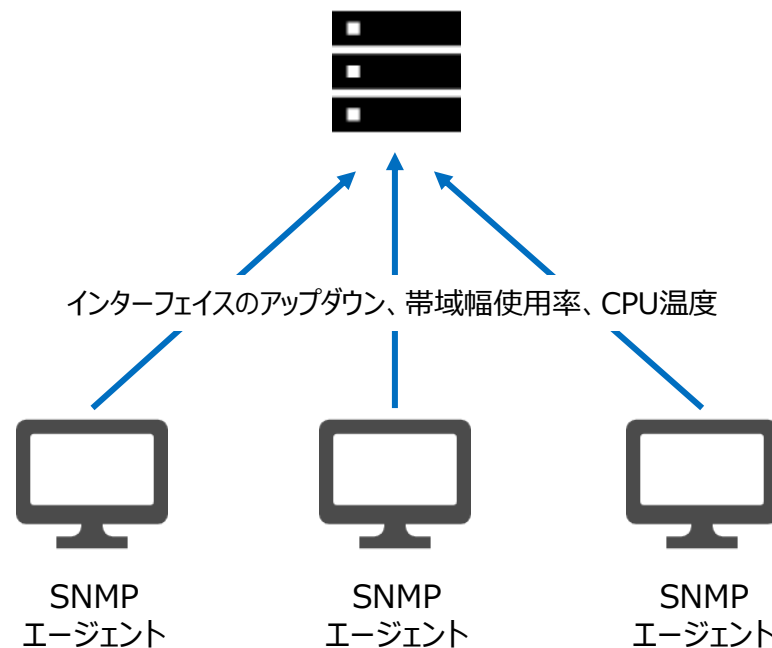
HTTPS (Hypertext Transfer Protocol Secure)

- TCPポート443を使用し、暗号化されたWebデータをSSLまたはTLS経由で転送します。
- 基本WEBサイトに採用されているべきです。最新のブラウザでは安全ではないWebページでは警告してくれるものもある。

● SNMP (Simple Network Management Protocol)

- デバイスを監視するためのネットワーク管理プロトコルです。SNMPエージェントはUDPポート161を使用します。
- ネットワークデバイス上に配置したSNMPエージェントからインターフェイスのアップダウン、帯域幅使用率、CPU温度などを取得します。
- SNMPv1およびv2は、ネットワークを介して平文で送信されます。そのため、盗聴または推測できてしまうためSNMPv3は機密性や認証機能を持っているためSNMPを利用される際にはv3を推奨します。

SNMP



アプリケーション通信

ウェルノウンポート



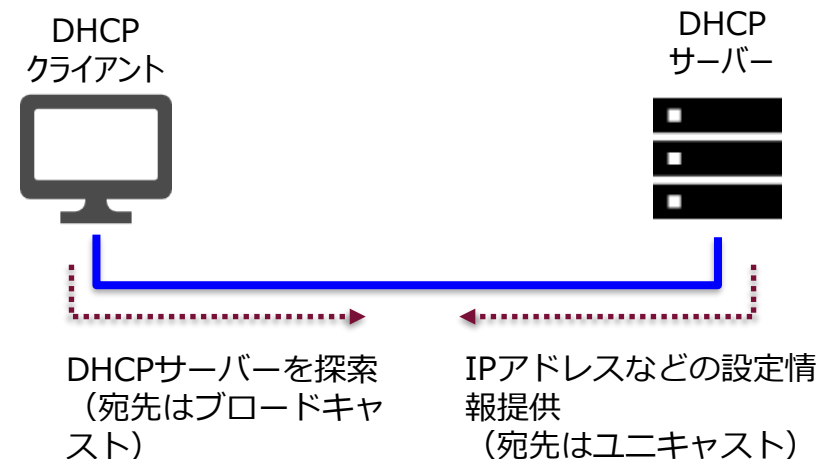
● BOOTP、DHCP

BOOTP (Bootstrap Protocol)

- サーバにはUDPポート67・クライアントにはUDPポート68を使用し、コンピュータなどの機器がネットワーク上の管理用の機器から自動的にネットワーク設定を取得するための通信プロトコルです。
- ネットワーク経由のブートストラップするためのブートストラッププロトコルとしても利用されます。ブートストラップとは、電源を入れてからOS起動までの一連の動作を指します。多くのBIOSはBOOTPをサポートしているため、デフォルトでネットワーク経由でオペレーティングシステムをロードします。IPアドレスとOSイメージ名を決定し、次にTFTPを使用してオペレーティングシステムをダウンロード行う。

DHCP (Dynamic Host Configuration Protocol)

- サーバにはUDPポート67、クライアントにはUDPポート68を使用します。
- BOOTPと同じ役割を果たし、一時IPアドレスをリースして、端末のIPアドレスとして割り当てることができます。



アプリケーション通信

リモート接続



● リモートデスクトップコンソールアクセス

RDP (Remote Desktop Protocol)

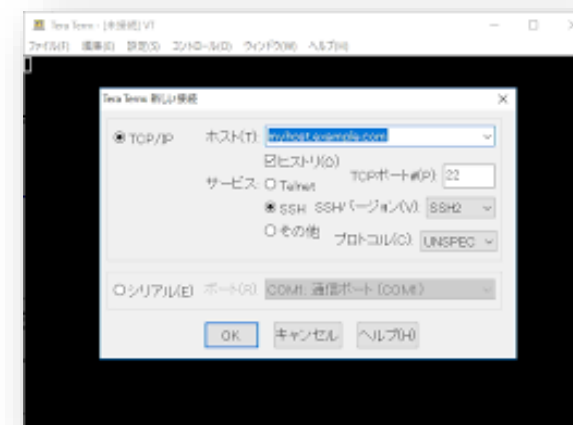
- デスクトップへのアクセスは、通常TCP5900で実行されるVNC (Virtual Network Computing) とTCPポート3389で通常実行されるRDP (Remote Desktop Protocol) があります。RDPは、Microsoft独自のプロトコルであり、一般のWindowsで使えます。

SSH (Secure Shell)

- コンソールへのリモートアクセスには、TCPポート22を使用します。



RDPの接続画面



TeraTermによるコンソール接続画面

アプリケーション通信

リモート接続



● 仮想デスクトップ基盤（VDI、Virtual Desktop Infrastructure）

デスクトップ環境を仮想化する技術であり、パソコンのデスクトップ環境をサーバ上に集約してサーバ上で稼働させる仕組みである。利用者はクライアントPCからネットワーク経由で仮想マシンに接続して、デスクトップ画面を呼び出した上で操作を行います。

VMware HorizonやCitrix Virtual Apps and Desktopsといった製品が展開されています。

仮想デスクトップ基盤の利点

- VDIではデータ自体をクライアント端末に保持しないため、セキュアな構成とされます。
- VDIではサーバ上に利用者数に見合う多数の仮想マシンを実装して、それぞれにデスクトップOSやアプリをインストールするため、従来のような利用者ごとのPCにOSやアプリをインストールする形式に比べるとサーバ上で集中管理することから各種ソフトウェアの追加や更新などのメンテナンスが容易になるメリットがあります。

シンクライアント

- クライアント側の端末（PC等）では限られた処理しか行わず、アプリケーションの実行やデータの管理などほとんどの処理をサーバー側に任せる仕組みです

ゼロクライアント

- WindowsやLinuxなどのOSを一切搭載せず、ネットワーク接続と画面描画・ディスプレイ出力、キーボード・マウス入力のみを備え、OSやアプリケーション実行環境のほぼすべてを仮想化デスクトップ機能によりサーバー上で実行されている端末です。

アプリケーション通信

リモートミーティング



● リモート会議テクノロジー

デスクトップ共有機能など、ユーザーがインターネット経由でオンライン会議を実行できるようにする新しいテクノロジーです。

通常、会議に接続されているすべてのPCでのPowerPointスライドの表示、スプレッドシートなどのドキュメントの共有、場合によってはオーディオやビデオの共有が含まれます。一部のソリューションでは、ユーザーがリモートミーティングテクノロジーで接続されている別のPCが操作できます。



リモート会議テクノロジーアプリの主な確認観点

- 多要素認証などの強力な認証技術を使用しているか。
- 通信が暗号化されているかどうか。その暗号化は、エンド・ツー・エンドで実施されるのか、中継サーバまでなのか。
- チャット等でやり取りしているドキュメントなどのコンテンツに対して削除が可能か、どこに保管されるのか。
- 未承認者に対してプライベートな会議に参加することを拒否できる機能が備わっているか。
- ユーザーの活動は監査され、ログに記録されるか。
- リモートミーティングのプラットフォーム自体が、どのようなトラッキングメカニズムを使用しているか。
- トラッキングを無効にすることができるか、データは何のために収集されるか。
- 参加者は会議の中で画像、ビデオ、ファイル共有ができるか。

アプリケーション通信

リモートミーティング



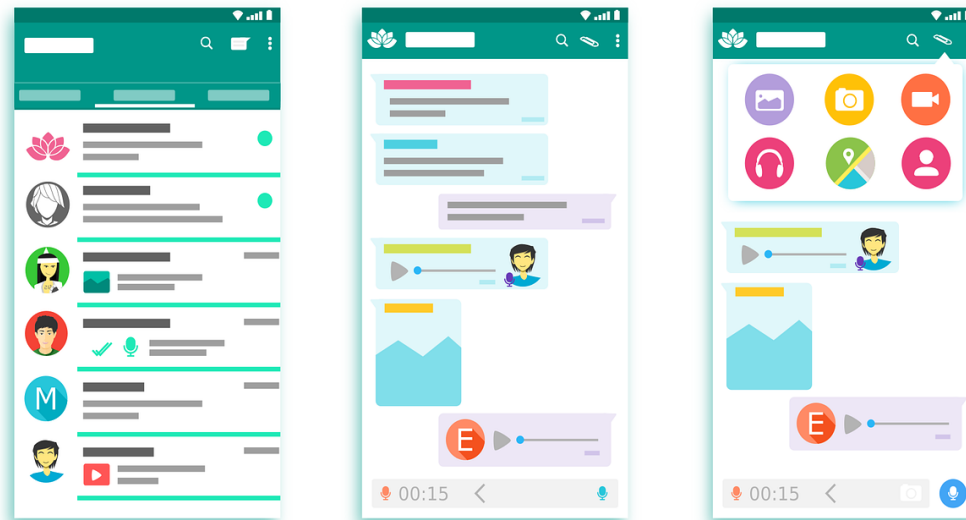
● インスタントメッセージング

2人以上のユーザーがリアルタイムの「チャット」を介して相互に通信が可能となります。チャットは、グループを介して1対1または多対多の場合があります。チャットに加えて、最新のインスタントメッセージングソフトウェアのほとんどは、ファイル共有、場合によっては音声およびビデオ会議を可能にしている。

インスタントメッセージングプロトコルにはIRC（Internet Relay Chat）があり、1988年に作成されたものであるが、今日でも人気があります。

インスタントメッセージの脆弱性

- 組織の場合、チャットソフトウェアの使用を制御するポリシーと、利用範囲を監視し、必要に応じてブロックするための技術的制御を実施する必要があります。



アプリケーション通信

リモートミーティング



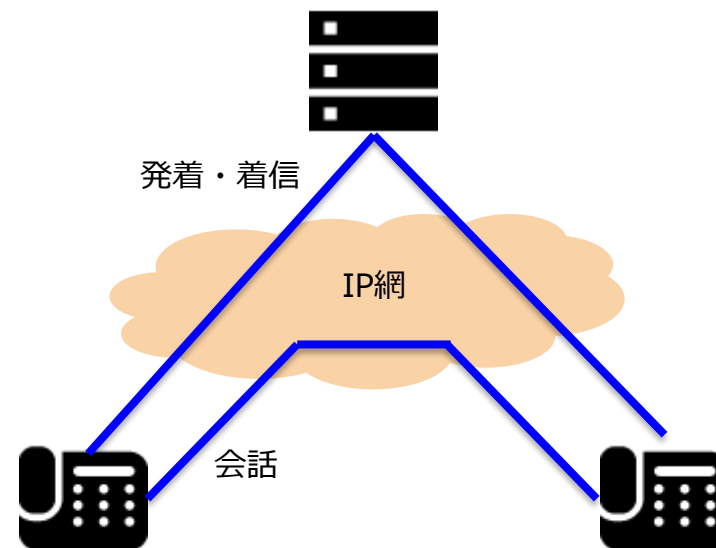
●VoIP (Voice over Internet Protocol)

IPネットワークを介して音声を伝送するプロトコルです。

アナログPOTS (Plain Old Telephone Service) の基本的な機能であり、現代も使用され続けている。その理由は低コストや復元力にあり、パケット交換ネットワークの利点を電話として利用できるためです。

一般的なVoIPプロトコルには、ストリーミングオーディオとビデオを伝送するように設計されたReal-time Transport Protocol (RTP) で提供されている。VoIPは魅力的なコスト上の利点を提供できますが、セキュリティ上の懸念があります。

VoIP通話の盗聴は秘密性が無い分容易であり、ネットワークが危険にさらされた場合は、携帯電話などの他の方法を使用して帯域外通信を行うか、SRTP (Secure Real-time Transport Protocol) を使用して、機密性、整合性、安全な認証などの安全なVoIPを行うようにしてください。



アプリケーション通信

産業通信



●分散ネットワークプロトコル（DNP3、Distributed Network Protocol）

電力会社や水道施設などの工業分野でよく利用される

SCADA（Supervisory Control And Data Acquisition）のオープン通信プロトコルセットです。

安定度の低い通信回線を利用しても確実にデータの送受信が可能であり、広域分散設備の制御に導入されています。

マスターステーションと呼ばれる中央制御機構から、各種デバイスとなる高性能電子装置（IED）や統括するリモートターミナルユニット（RTU）などからなるアウトステーションとの通信に利用します。

DNP3.0プロトコルの通信方法は、シリアル通信とIPネットワーク通信の2種類をサポートしている。IPネットワーク通信ではTCPとUDPをサポートしており、DNP3.0データをインターネット上に流し遠く離れた装置も操作やデータ収集もすることが可能です。

SCADAシステム



マスターステーション



リモートターミナル
ユニット（RTU） 高性能電子装置
（IED）

アウトステーション



ネットワーク障害

関連用語

- クリスマスツリー攻撃
- Teardrop
- 悪魔の双子攻撃 (Evil Twin)
- Smurf攻撃
- LAND攻撃
- Fraggle攻撃
- キャプティブポータル
- ウォードライビング

ネットワーク障害

ネットワーク攻撃

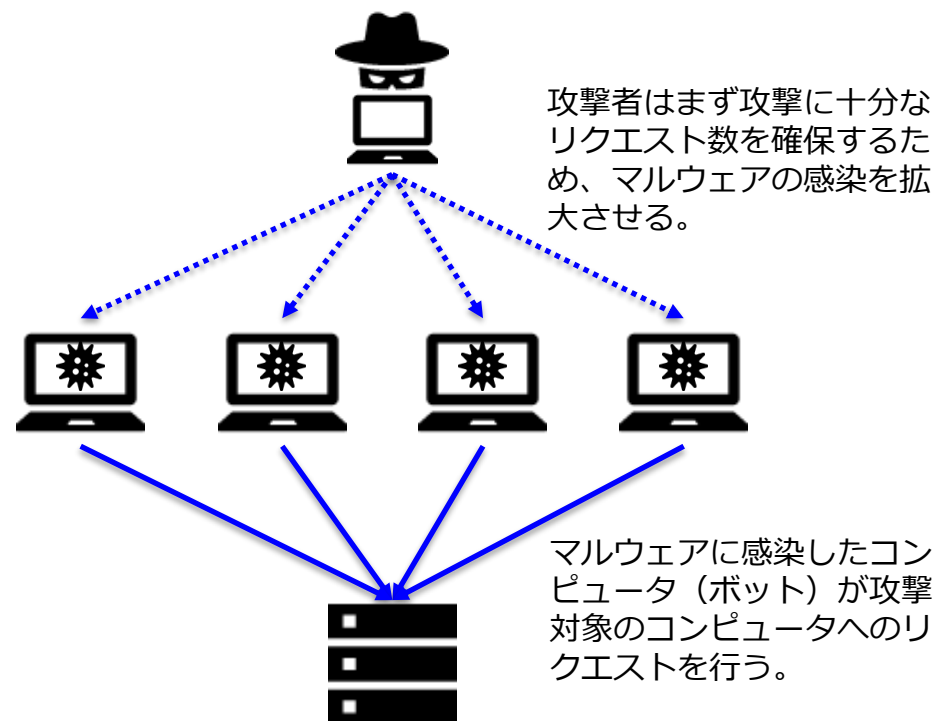
● ネットワーク障害

ネットワーク障害の種別

- レイテンシとは、パケットが遅延することです。
- 干渉とは、パケットが他の通信によってデータ内容を崩すことです。
- パケットロスとは、パケット自体が紛失してしまうことです。
- ジッタとは、パケットの遅延の長さの揺らぎのことです。

サービス拒否攻撃、DoS攻撃（Denial of Service）

- Webサービスを稼働しているサーバやネットワーク機器に対して、大量のリクエストを送付することでリソースに意図的に過剰な負荷をかける攻撃です。
- 通常1つの攻撃対象に対して1つの端末から攻撃を行うことはなく、あらゆる端末から一つのターゲットに対して攻撃を行うため、分散型サービス拒否攻撃、DDoS攻撃（Distributed Denial of Service attack）として行われます。
- クラウドの従量課金制を狙い、アクセス負荷をかけ経済的な負担に発展させるものもあります。





ネットワーク障害

ネットワーク攻撃

● ネットワーク障害

Smurf攻撃

- DoS攻撃の一種であり、攻撃対象となる通信機器のIPアドレスを送信元アドレスに偽装し、大量のICMPパケットをブロードキャストで送信する攻撃です。

Teardrop

- IPパケットの分割前に戻すときのオフセットを偽造することでシステムを停止させる攻撃です。
- 一つのパケットで送付できない程の大きなデータである場合、順列のオフセット番号を付与してから送付し、受信側で組み立てます。
- 通常では想定されていないパケットを送付することで制御系を狙う攻撃の一種であり、オフセット番号を他のパケットと重複するように偽装し、受け取り側を停止させます。

TCPのパケット構造

受信ポート
送信ポート
シーケンス番号
確認応答番号
データオフセット
予約済み
フラグ
ウィンドウ
チェックサム
緊急ポインター
オプション
パディング
データ内容

分割された送られたパケットの内容（主にデータ内容）の順番を管理

ネットワーク障害

ネットワーク攻撃

● 攻撃対象の調査

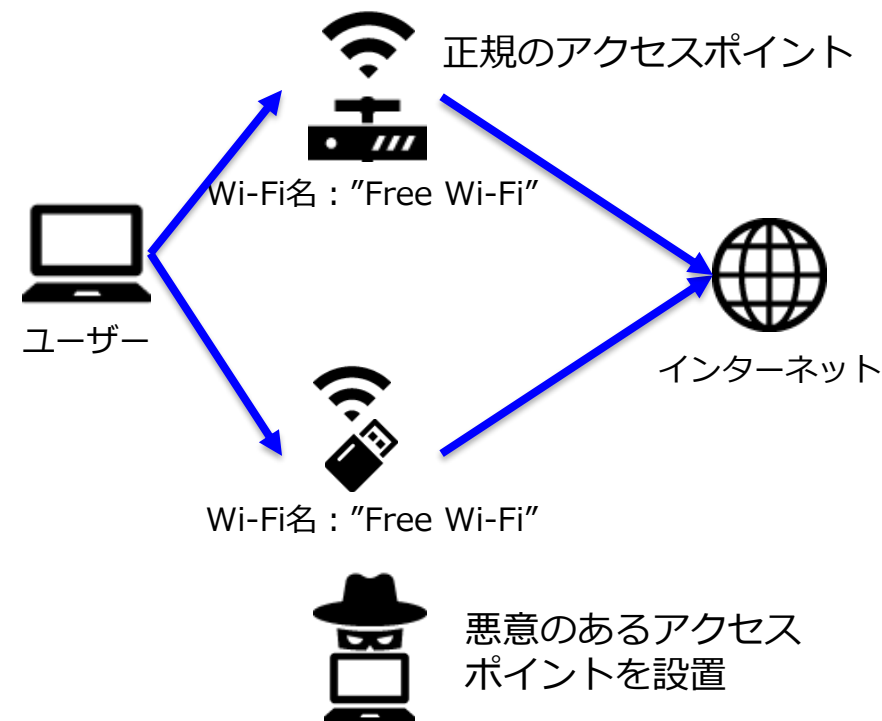
クリスマスツリー攻撃

- TCPパケットにいくつかのTCPフラグ（URG、ACK、PSH、RST、SYN、FIN）を立てて送り、応答を観察する攻撃です。
- 確認パケットでは部分的にフラグを付け替えることでネットワーク機器の動作を確認します。すべてのフラグを立てているにも関わらず、受け取り手の異なる反応をすると、サービスが停止しているなど他と何か違うことが判断できます。

● ユーザーに対するネットワーク攻撃

悪魔の双子攻撃（Evil Twin Attack）

- ホテルやカフェなどの無料Wi-Fiの偽物を設置し、ユーザー情報を盗みだす攻撃です。
- 無料のWi-Fiが危険といわれる原因であり、インターネットに接続する際の同意画面も偽装である場合もあるため、見慣れている画面だからと安心するのは非常に危険です。



PIEDPINの紹介



なぜセキュリティを学ぶのか

セキュリティの最も大きな敵は、人はあらゆるものに慣れ、そのリスクを考えなくなる習性にあります。セキュリティの学びを通して得られる貴重なものは、あらゆる事象に対して好奇心を持つことであり、それは目まぐるしい現代を生きるのに大いに役立つでしょう。

- EASY DESIGN
- SUPER EFFICIENT
- EVERYWHERE

PIEDPINを選ぶ理由



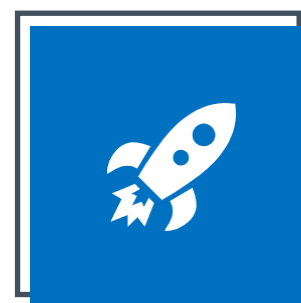
**EASY
DESIGN**

日本語で学べる



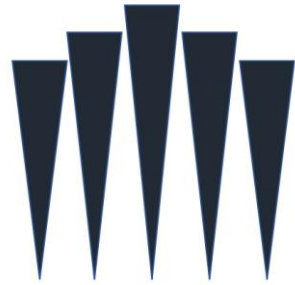
**SUPER
EFFICIENT**

わかりやすい説明



EVERYWHERE

どこからでも学べる環境



THANK YOU

CISSP for BEGINNER